GTAG

GUIDE PRATIQUE D'AUDIT DES TECHNOLOGIES DE L'INFORMATION

Management de l'audit des systèmes d'information

The Institute of Internal Auditors

Guide pratique d'audit des technologies de l'information (GTAG) 4 : Management de l'audit des systèmes d'information

Auteur principal
Michael Juergens, Principal, Deloitte & Touche LLP

Contributeur
David Maberry, Senior Manager, Deloitte & Touche LLP

Avec la collaboration de
Eric Ringle, Senior Manager, Deloitte & Touche LLP
Jeffrey Fisher. Senior Manager, Deloitte & Touche LLP

Mars 2006

Copyright © 2005 par l'Institute of Internal Auditors, 247 Maitland Avenue, Altamonte Springs, Florida 32701-4201. Tous droits réservés. Imprimé in the United States of America. Aucune partie de cette publication ne peut être reproduite, stockée dans un système de consultation ou transmise sous quelque forme que ce soit, ni par aucun moyen (électronique, mécanique, reprographie, enregistrement ou autre), sans autorisation préalable de l'éditeur.

L'IIA publie ce document à titre informatif et pédagogique. Cette publication entend donner des informations, mais ne se substitue en aucun cas à un conseil juridique ou comptable. L'IIA ne fournit pas ce type de service, et la publication du présent document ne s'accompagne d'aucune garantie quant aux résultats juridiques ou comptables. En cas de problèmes juridiques ou comptables, il convient de recourir aux services de professionnels.

GTAG — Table des matières

1. Résumé ... 1
2. Introduction ... 2
3. Définition des SI ... 4
   3.1 Management des systèmes d'information ... 5
   3.2 Infrastructure technique ... 5
   3.3 Applications ... 6
   3.4 Connexions extérieures ... 6
4. Risques liés aux SI ... 7
   4.1 La théorie du flocon de neige ... 7
   4.2 Évolution des risques ... 7
   4.3 Prolifération du risque lié aux SI ... 8
   4.4 Types de risques liés aux SI ... 8
   4.5 Évaluation des risques liés aux SI ... 8
5. Définir l'univers de l'audit ... 11
   5.1 Conseils à l'intention du responsable de l'audit interne ... 11
   5.2 Définir le budget de l'audit des SI ... 12
6. Réaliser un audit des SI ... 13
   6.1 Cadres de référence et normes ... 13
   6.2 Gestion des ressources d'audit des SI ... 15
7. Les accélérateurs de l'audit des SI ... 18
   7.1 Facilitateurs d'audit ... 18
   7.2 Accélérateurs de tests ... 18
8. Questions que doit se poser le responsable de l'audit interne ... 21
A. Annexe A – Problématiques nouvelles ... 22
   A.1 Réseaux sans fil ... 22
   A.2 Systèmes mobiles ... 22
   A.3 Interfaces ... 23
   A.4 Gestion des données ... 23
   A.5 Protection de la vie privée ... 24
   A.6 Séparation des fonctions ... 24
   A.7 Accès administrateur ... 25
   A.8 Contrôles configurables ... 26
   A.9 Piratage ... 27
   Autres ressources ... 27

Les auteurs ... 29

Les systèmes d'information (SI) changent la nature de la fonction d'audit interne. Avec l'apparition de nouveaux risques, de nouvelles procédures d'audit sont nécessaires pour gérer correctement ces risques. Le présent guide, qui a pour vocation d'aider le responsable de l'audit interne à gérer la fonction d'audit des SI plus efficacement et avec davantage d'efficience, décrit comment :

Définir les SI – Quels sont les domaines à inclure dans un plan d'audit des SI ? Le responsable de l'audit interne doit être capable de décider de l'étendue à donner à son audit des SI en s'appuyant sur les lignes directrices présentées dans ce document, afin que les procédures d'audit des SI couvrent un périmètre adéquat.

Évaluer les risques liés aux SI – Il est évident que l'évolution des SI introduit des risques nouveaux dans l'organisation. Le présent guide aide le responsable de l'audit interne à comprendre comment identifier et quantifier au mieux ces risques relatifs aux SI. Ainsi, les procédures et les ressources de l'audit des SI pourront se recentrer sur les domaines qui présentent les risques les plus importants pour l'organisation.

Définir l'univers de l'audit des SI – Les ressources d'audit des SI sont généralement peu nombreuses, alors que les demandes abondent. La section consacrée à la définition de l'univers de l'audit des SI aidera le responsable de l'audit interne à comprendre comment élaborer un plan d'audit des SI qui optimise l'utilisation des ressources en fonction des besoins.

Exécuter les audits des SI – La prolifération et la complexité des SI impose d'élaborer de nouvelles procédures d'audit des SI. L'audit effectué d'après des listes de vérification ou sur la base d'une enquête risque d'être insuffisant. Cet ouvrage indique précisément au responsable de l'audit interne comment exécuter les procédures d'audit des SI et quelles normes et quels cadres de référence existent pour supporter ces procédures.

Gérer la fonction d'audit des SI – Gérer la fonction d'audit des SI peut demander de nouvelles techniques et procédures. Le présent guide propose des suggestions et des techniques permettant de maximiser l'efficacité de cette fonction et d'en gérer les ressources.

Résoudre les problématiques émergentes – Les SI évoluent rapidement. Cette évolution peut induire des risques nouveaux non négligeables pour l'organisation. Le responsable de l'audit interne de haut niveau cible donc l'audit non seulement sur les composantes élémentaires des SI, mais aussi sur les technologies nouvelles et émergentes. Une section consacrée aux problématiques émergentes apporte des informations précises sur plusieurs technologies récentes, évalue les risques que ces technologies induisent pour l'organisation et formule à l'intention du responsable de l'audit interne des recommandations sur la manière de traiter ces risques.

Ce guide a pour ambition de présenter des informations pragmatiques dans un langage facilement compréhensible, et de proposer des recommandations précises que le responsable de l'audit interne pourra mettre en œuvre immédiatement. Il suggère en outre des questions que ce responsable peut se poser pour déterminer si sa fonction d'audit des SI est performante.

Il ne fait aucun doute que les SI sont en train de changer la nature de la fonction d'audit interne. Les responsables de l'audit interne doivent aujourd'hui s'interroger sur les risques auxquels doit faire face l'entreprise, sur les types d'audits à effectuer, sur les priorités à instaurer dans l'univers d'audit et sur la manière de formuler des constats pertinents. Cependant, en l'absence de bases techniques solides, il peut être difficile de répondre à toutes ces questions, entre autres.

Ce GTAG s'adresse aux responsables de l'audit interne et aux personnels d'encadrement de l'audit interne qui sont chargés de superviser les audits des SI. Il a pour vocation de les aider à répondre aux questions stratégiques concernant la planification, l'exécution et les rapports d'audit des SI. Il étudie les aspects fondamentaux ainsi que les considérations émergentes.

Dans la mesure où les organisations sont de plus en plus tributaires des SI, l'audit des SI revêt une importance croissante. Les processus clés sont automatisés ou activés par la technologie. Ainsi, il est aujourd'hui possible de récupérer un bon de commande sur un site Web, de l'envoyer à l'entrepôt puis d'expédier la marchandise au client sans que le bon de commande ne soit vu ou touché par d'autres personnes que l'agent qui travaille dans l'entrepôt.

À mesure que les organisations accentuent leur dépendance aux SI, deux grands problèmes se posent :

- **Un pourcentage important des contrôles internes clés déterminants pour l'organisation sont susceptibles d'être activés par la technologie.** Exemple : la politique d'une entreprise précise qu'avant de régler la facture d'un fournisseur, il convient de procéder à une triple concordance. Autrefois, c'était un employé de bureau qui procédait à ce rapprochement : il rassemblait physiquement les documents, les agrafait et les classait. Aujourd'hui, le système d'ERP (planification des ressources de l'entreprise) est capable de mener à bien toute la procédure. Il procède automatiquement au rapprochement sur la base de règles et de niveaux de tolérance préconfigurés et reporte automatiquement les écarts dans des comptes d'écart prévus à cet effet.
  Pour auditer efficacement ce contrôle, un auditeur doit se rendre dans les paramètres de configuration du système d'ERP et évaluer les règles et paramètres. Il a pour cela besoin d'un ensemble de compétences et d'un programme d'audit bien différents de ceux requis par le processus manuel d'autrefois. Pour auditer ce contrôle de façon efficace, il convient donc de revoir l'approche classique de l'audit pour tenir compte des risques nouveaux et pour cela, il est impératif de s'intéresser à la technologie de l'audit et de la maîtriser.
- **Les systèmes dont l'intégrité est compromise ou dont les contrôles sont défectueux produiront un impact plus important sur les opérations de l'organisation et sa compétitivité, ce qui renforcera la nécessité de disposer de contrôles informatiques efficaces.** Exemple : considérons le processus automatisé décrit plus haut, dans lequel le bon de commande arrive via un site Web et est transmis directement à l'entrepôt par le système d'ERP. Voyons maintenant ce qui se passe lorsqu'un client commande par erreur 100 palettes au lieu de 100 unités. Si l'organisation a entièrement optimisé ses processus au sein du système d'ERP, il est possible que le système vérifie le stock, constate qu'il n'y a pas 100 palettes disponibles, révise le plan de production afin de produire 100 palettes et envoie automatiquement des bons de commande pour des matières premières via l'échange de données informatisées (*Electronic Data Interchange*, EDI). Il est possible que cette erreur ne soit pas détectée avant que le client ne reçoive les marchandises, c'est-à-dire trop tard.

De toute évidence, pour atténuer ce type de risques, les organisations doivent exécuter des plans de SI bien conçus tenant compte de ces problèmes. Malheureusement, la plupart d'entre elles n'ont migré vers des environnements fortement automatisés qu'au cours de la dernière décennie, voire plus récemment. Elles ne sont donc pas forcément très portées sur la technologie de l'audit, ni à l'avant-garde de la réflexion sur la manière de l'auditer. Ces insuffisances s'expliquent en partie par le rythme rapide des progrès technologiques. La triple concordance n'a peut-être pas connu d'évolution radicale pendant de nombreuses années, mais les applications utilisées pour ces processus évoluent chaque année.

De plus, la planification de l'univers de l'audit des SI requiert souvent de bien comprendre les liens entre les contrôles informatiques et la communication financière, la fraude ainsi que d'autres problèmes clés. C'est relativement facile à saisir lorsque vous évaluez des contrôles dans le cadre d'un système applicatif (par exemple les paramètres de la triple concordance évoqués plus haut). Cependant, c'est beaucoup plus difficile lorsque vous évaluez les technologies sous-jacentes. Supposons que l'organisation ait une connexion Internet, mais pas de pare-feu pour protéger son réseau interne. Les données financières risquent-elles d'être faussées ? Les opérations sont-elles touchées ? Plus la technologie est éloignée des opérations de l'entreprise, plus il devient difficile d'établir une corrélation directe.

Ainsi, de nombreux responsables de l'audit interne accordent souvent moins d'attention à ces technologies, ce qui peut constituer une approche plutôt à courte vue du risque lié aux SI. En réalité, les défaillances des contrôles des technologies support peuvent produire un impact bien plus fort sur l'organisation que les contrôles informatiques spécifiques à un processus.

Supposons par exemple qu'une organisation émette des paiements électroniques qu'elle envoie à ses fournisseurs. Ces paiements sont acheminés par voie électronique vers des comptes bancaires sur la base des numéros de routage de la chambre de compensation automatisée (ACH) pour chaque compte fournisseur. Tous ces numéros ACH sont stockés quelque part dans une table du système de base de données de

l'organisation. Un administrateur de base de données, ou quiconque disposant du droit d'accès à la base de données, peut facilement modifier n'importe quelle entrée de cette table pour y faire figurer le numéro ACH de son propre compte bancaire. La prochaine fois que l'organisation enverra des chèques électroniques, l'intégralité des chèques seront crédités sur le compte bancaire du contrevenant. Une telle manipulation contournerait tous les mécanismes de sécurité, de contrôle et de piste d'audit en place au sein du processus et de l'application, y compris le mode « positive pay ».

Dans les scénarios ci-dessus, il est facile de comprendre comment la défaillance d'un contrôle au niveau de la base de données peut produire davantage de dégâts qu'une défaillance au niveau des paramètres de la triple concordance. C'est la raison pour laquelle les responsables de l'audit interne doivent scrupuleusement tenir compte de toutes les couches de l'environnement de SI lorsqu'ils planifient leur univers d'audit des SI pour l'année.

Lorsqu'il élabore le plan annuel d'audit des SI, le responsable de l'audit interne doit commencer par définir les limites des SI (systèmes d'information). Le téléphone et les messageries vocales en font-ils partie ? Faut-il y inclure les systèmes de badge et de sécurité physique ? Et que faire si ces derniers sont externalisés à une société de gestion immobilière qui gère les locaux ? Voici quelques-unes des questions auxquelles le responsable de l'audit interne doit répondre lorsqu'il s'efforce de déterminer comment allouer ses ressources d'audit des SI.

En fait, les SI recouvrent une réalité différente suivant les organisations. Même deux entreprises opérant dans le même secteur peuvent avoir des environnements de SI très différents. Malheureusement, il n'existe pas de définition claire ou universelle des SI.

Cette section aidera les responsables de l'audit interne à envisager les SI dans le cadre de l'organisation. Sachant que les environnements de SI sont très hétérogènes, un responsable de l'audit interne peut chercher à définir les SI en l'envisageant sous forme de couches, comme un gâteau. Chaque couche est différente des autres et importante. Chaque couche de l'environnement présente des risques, qui varient considérablement. Ainsi, le piratage du site Web de l'entreprise représente un risque très différent, pour l'organisation, du risque de détournement des émissions de chèques électroniques évoqué plus haut.

Tenir compte de chaque couche

Pour une fonction d'audit des SI efficace, il convient d'étudier et de classer par ordre de priorité les risques inhérents à chaque couche, puis d'allouer les ressources d'audit à chaque couche. Si le plan d'audit des SI ne prévoit pas d'audit pour chaque couche de l'environnement, il est fort probable que le plan d'audit dans son ensemble ne traite pas correctement les risques liés aux SI de l'organisation.

Il convient de noter que, dans certains cas, il peut se révéler utile d'envisager toutes les couches sur la durée (c'est-à-dire sur plusieurs années, par rotation) au lieu de couvrir toutes les couches sur une seule année. Les entreprises privées ou les organisations qui n'ont pas besoin de se conformer à la loi Sarbanes-Oxley de 2002 (États-Unis) ou à d'autres règles ou textes de loi, tels que le *Federal Deposit Insurance Corporation Improvement Act* (loi fédérale sur l'amélioration des entreprises d'assurance dépôts), peuvent souhaiter instaurer un plan couvrant l'univers des SI sur une période de deux à trois ans. Les plans rotatifs allant au-delà de trois ans sont probablement inadéquats en raison de la rapidité des changements qui s'opèrent dans l'environnement de SI.

Quel volume de ressources allouer à chaque couche ? À quel endroit de la couche les allouer ? La réponse à ces questions délicates devrait découler naturellement des processus d'évaluation des risques, associés au jugement et à la réflexion stratégique de l'auditeur. Indépendamment de l'allocation précise des ressources, il convient de prendre en compte toutes les couches.

Comment sont formées les couches ?

La figure 1 ci-après donne une représentation simple d'un environnement de SI. De toute évidence, chaque organisation est différente, mais ce graphique couvre la majorité des systèmes critiques pour la plupart des organisations.

Voici les principales couches :

- Management des systèmes d'information.
- Infrastructure technique.
- Applications.

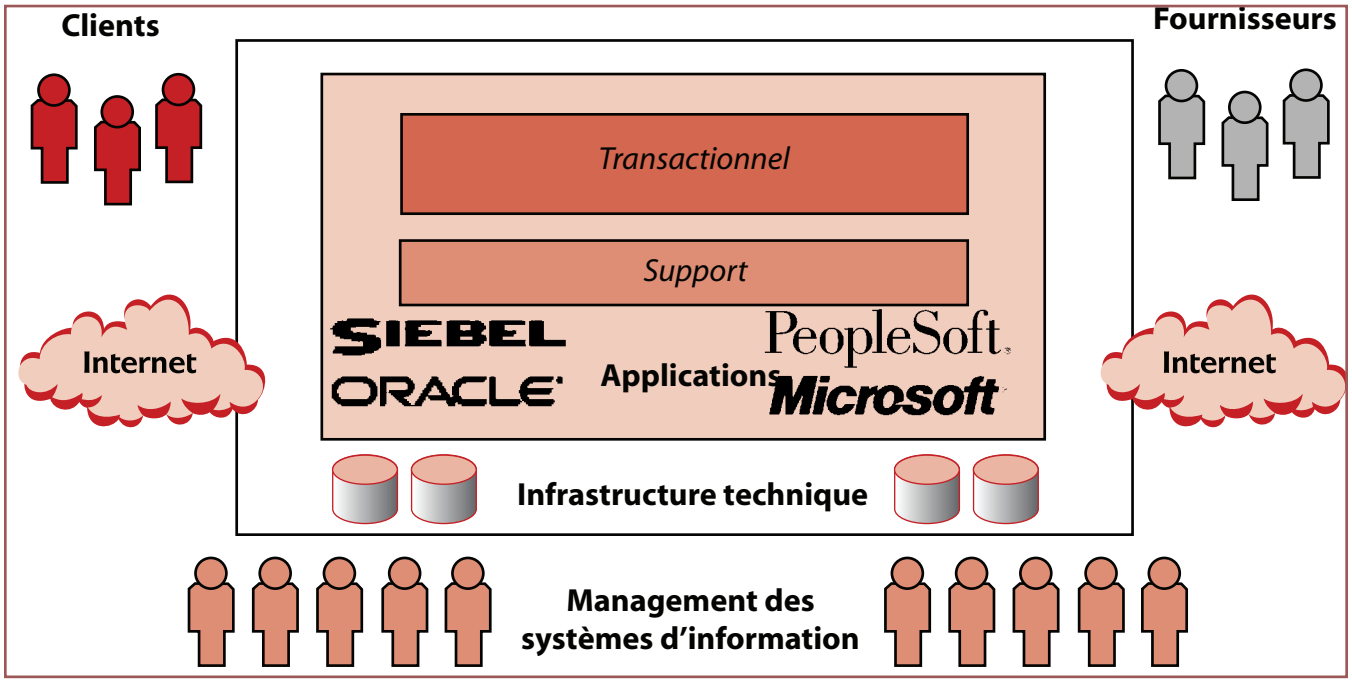

Figure 1 – Environnement de SI

- Connexions extérieures.

Il faut noter que ce graphique ne définit pas les catégories du plan d'audit des SI. Lorsque des audits des SI spécifiques sont planifiés, ils sont parfois organisés en catégories, selon les processus de l'organisation, ou en cadres de référence normalisés, etc. Ce graphique doit aider le responsable de l'audit interne à réfléchir à l'environnement de SI et à veiller à ce que des ressources d'audit soient allouées à chaque couche. L'organisation des audits spécifiques est laissée à l'appréciation du responsable de l'audit interne.

3.1 Management des systèmes d'information

Cette couche recouvre les personnes, les politiques, les procédures et les processus qui gèrent l'environnement de SI. Des technologies peuvent être déployées, par exemple une organisation peut se doter du progiciel d'ERP SAP dans un environnement Unix, mais l'intégrité des systèmes et des données est fortement tributaire de tâches précises que le personnel administratif exécute sur une base régulière. Cette couche inclut donc les éléments suivants :

Pilotage des systèmes – Le pilotage consiste à identifier les transactions qui ne sont pas imputées en raison d'une erreur de traitement, ou à repérer lorsqu'une base de données est corrompue.

Programmation – Beaucoup d'organisations programment divers systèmes en interne. Il convient alors de gérer et de superviser la programmation de manière à ce que les erreurs ne compromettent pas l'intégrité des principaux systèmes.

Planification – Le département informatique doit élaborer des plans stratégiques informatiques à court et à long terme. Ces plans doivent correspondre aux plans à court et long terme de l'ensemble de l'organisation. En l'absence d'une bonne planification stratégique, on ne saurait garantir que les SI soutiendront les objectifs de l'organisation considérée comme un tout.

Gestion des fournisseurs extérieurs – Nombre d'organisations confient diverses composantes de leur environnement de SI, voire toutes, à un prestataire extérieur. Dans ce cas, il est vital de gérer efficacement les relations avec ce fournisseur extérieur si l'on veut préserver l'intégrité de l'environnement de SI.

Gouvernance des SI – Donner résolument le ton depuis le sommet de la hiérarchie pour une conception, une mise en place et un fonctionnement intègres des SI ; diffuser cette culture dans toute la fonction informatique ; superviser le développement et le déploiement des politiques et procédures et évaluer les performances, telles sont les principales composantes de la gestion d'une fonction informatique.

Il convient de noter que les audits de ces fonctions seront analogues aux audits de processus. L'auditeur des SI considère les individus et les tâches, par opposition à la configuration d'un système technique. Les tests des contrôles seront très différents et demanderont de faire preuve de discernement.

3.2 Infrastructure technique

Cette couche est désignée sous de nombreuses appellations différentes, comme contrôles informatiques généraux, contrôles «pervasifs» ou technologies support. Elle regroupe essentiellement les systèmes qui sous-tendent, soutiennent et permettent l'exploitation des applications principales :

Systèmes d'exploitation – Ensemble des programmes qui indiquent aux systèmes informatiques comment fonctionner, par exemple Unix, Windows 2003 et OS/400. Tous les programmes et les fichiers finissent par résider quelque part dans le système d'exploitation. Les actions engagées au niveau du système d'exploitation parviennent en général à contourner la plupart des dispositifs de sécurité et des contrôles existant au niveau du processus. Prenons l'exemple de l'ordinateur portable d'un cadre. Si le cadre souhaite effacer un courrier électronique, il ou elle accèderait à la messagerie électronique et effacerait le mail. Le programme lui demande probablement « Êtes-vous sûr ? » Le message effacé est ensuite stocké dans un dossier spécial pendant un certain temps, afin de pouvoir être récupéré si nécessaire. Cependant, ce même cadre peut aussi ouvrir Windows Explorer et effacer tous les répertoires du lecteur C. L'effet serait le même : le courrier électronique aura disparu. Dans ce dernier cas, les contrôles sont clairement moins nombreux.

Bases de données – Toutes les données d'une activité, critiques ou non, finissent par résider dans une base de données quelque part dans l'environnement. Les bases de données se composent de tables qui contiennent les données, qui constituent notamment la base de tous les rapports d'activité de l'entreprise. Ces bases sont par exemple Oracle, MS SQL Server et DB2. Les actions engagées au niveau des bases de données ont aussi tendance à contourner la plupart des contrôles qui existent au niveau des processus, comme en témoigne l'exemple de fraude sur les comptes fournisseurs évoqué plus haut.

Réseaux – Pour que les données circulent dans une organisation, il faut qu'elles disposent d'un vecteur, qui peut être un câble, un câble à fibre optique ou un système sans fil. Le réseau se compose des éléments physiques tels que les câbles, des appareils qui gèrent le trafic sur le réseau, comme les commutateurs, les routeurs ou les pare-feux, et des programmes qui commandent la circulation des données. L'intégrité du réseau joue un grand rôle dans l'exhaustivité et l'exactitude des données d'une organisation. Par exemple, si un agent d'un entrepôt se préparant à expédier un produit le scanne avec un scanner à code barres, comment la transaction est-elle reportée sur le Grand livre général ? Réponse : elle passe

par le réseau et elle est traitée. Mais que se produit-il si elle ne passe pas par le réseau ? Que se passe-t-il si elle est modifiée en cours de route, ou disparaît complètement ? Comment l'organisation le saurait-elle ?

Les audits de l'infrastructure technique ont tendance à s'attacher davantage à l'examen des paramètres de configuration technique qu'aux processus.

3.3 Applications

Les applications métiers sont des programmes qui exécutent des tâches spécifiques liées aux activités de l'entreprise. Elles se classent principalement dans deux catégories : les applications transactionnelles et les applications de support.

Applications transactionnelles

Les applications transactionnelles sont principalement des logiciels qui traitent et enregistrent les transactions, par exemple des logiciels de traitement des bons de commande, de saisie dans le Grand Livre général et de gestion des entrepôts. Les applications transactionnelles se rangent généralement dans l'une des catégories suivantes :

- **Côté achat :** permet les processus d'approvisionnement et de la chaîne d'approvisionnement *(supply chain)*.
- **Côté vente :** permet les processus de vente et de distribution.
- **Back Office :** permet les processus liés à la comptabilité financière, aux créances fournisseurs et clients et aux ressources humaines.
- **ERP :** logiciel intégré qui exécute une ou plusieurs des fonctions ci-dessus.

Applications de support

Les applications de support sont des logiciels spécialisés qui facilitent les activités des entreprises mais ne traitent généralement pas les transactions. Ce sont par exemple des logiciels de messagerie électronique, de télécopie, d'imagerie et de conception.

Or, l'essentiel de l'audit doit se consacrer aux applications transactionnelles. Cependant, dans certains secteurs, les applications de support peuvent, elles aussi, présenter des risques élevés. Exemple : la société XYZ fabrique un bien de consommation sous une marque très reconnaissable. Elle ne cesse de perdre de l'argent en raison de contrefaçons bas de gamme vendues par des entreprises qui les copient. Son équipe de créateurs dessine de nouveaux produits dans un progiciel de conception intégrée. Dans ce cas, la société doit évaluer les contrôles dans cette application de support, qui peut faire courir un risque financier à la société si les nouveaux plans sont volés avant que les produits ne soient commercialisés.

3.4 Connexions extérieures

Le réseau de l'entreprise n'est pas coupé du reste du monde, mais très probablement relié à de nombreux autres réseaux extérieurs. Internet est naturellement celui qui vient le premier à l'esprit, mais trop souvent, les responsables de l'audit interne commettent l'erreur de ne pas regarder plus loin. En réalité, il est très probable que le réseau de l'entreprise soit aussi connecté à beaucoup d'autres réseaux. Par exemple : l'organisation opère-t-elle via l'EDI ? Si tel est le cas, son réseau est certainement connecté à celui d'un prestataire d'EDI, ou peut-être directement au réseau d'un partenaire commercial. L'organisation externalise-t-elle sa fonction d'entreposage ? Si oui, les deux réseaux sont aussi probablement reliés.

De plus, dans la mesure où les organisations continuent d'automatiser leurs processus clés, les externes ont de plus en plus accès à leur réseau, souvent via Internet. Prenons par exemple la possibilité de vérifier le solde d'un compte bancaire ou l'état d'avancement d'un envoi par FedEx. Les clients qui utilisent ces fonctions entrent probablement dans le réseau interne de ces entreprises via Internet.

Le problème réside ici dans le fait que l'organisation ne maîtrise pas les réseaux extérieurs, et donc qu'elle ne doit pas leur faire confiance. Toute communication depuis et vers les réseaux extérieurs devrait être strictement contrôlée et surveillée. Il peut être difficile de définir les procédures d'audit des SI face à ce risque, car l'organisation ne peut auditer que ce qu'elle contrôle, et il est donc vital d'auditer au minimum les points d'entrée et de sortie.

4.1 La théorie du flocon de neige

Chaque environnement de SI est unique, et représente donc un ensemble de risques unique, selon la théorie du flocon de neige. En raison des différences entre les environnements de SI, il est de plus en plus difficile d'adopter une approche générique ou par checklist de l'audit des SI. Pour être efficace, chaque organisation doit définir son approche de l'audit des SI et élaborer des plans de travail répondant spécifiquement aux besoins de son environnement.

L'audit des SI diffère fortement de l'audit financier ou opérationnel, qui s'intéresse à des risques endémiques dans un secteur donné ou pour des entreprises d'une taille donnée. Prenons l'exemple suivant : la société ABC et la société XYZ opèrent toutes deux dans le secteur des médias et du spectacle. Toutes deux sont exposées à un risque lorsqu'elles calculent le total définitif des entrées payantes pour les films qui sont sortis. La fonction d'audit interne s'intéresserait forcément à ce processus.

Du côté des SI, toutefois, ABC utilise essentiellement Oracle Applications, sur Windows 2000, avec une base de données Oracle. Il s'agit d'un système Oracle centralisé. XYZ est dotée d'une fonction informatique décentralisée, et chacune des entités utilise son propre système, sur diverses plateformes. Chacune communique ses données à un système de consolidation, que la société a externalisé à un prestataire tiers. De toute évidence, les audits des SI qui seront planifiés et exécutés pour la société ABC différeront largement de ceux destinés à la société XYZ.

Le facteur de la configuration

La configuration constitue un autre facteur qui entre en ligne de compte dans la théorie du flocon de neige. Lorsqu'une entreprise déploie une technologie donnée, elle la configure en fonction de ses objectifs particuliers. On peut donc observer des variations considérables d'un environnement à l'autre. Une entreprise qui utilise Windows 2003 comme principal système d'exploitation peut avoir mis en place de multiples domaines, qui entretiennent entre eux des relations de confiance. Une autre n'aura en revanche qu'un seul domaine, et utilisera Windows Active Directory pour gérer tous les accès utilisateurs. Même si les deux entreprises emploient la même technologie, les risques qu'elles courent sont très différents, et donc elles feront aussi l'objet d'audits des SI très différents.

La configuration influe aussi sur les applications métiers. La société ABC et la société XYZ ont toutes deux opté pour SAP comme principal système d'entreprise, qui gère le processus des créances fournisseurs. ABC a configuré SAP pour qu'il procède à une triple concordance entre le prix, le volume et la date. Elle a fixé des tolérances inférieures et supérieures de 50 dollars ou 5 %, suivant la valeur la plus faible. XYZ a configuré SAP pour qu'il procède à un « règlement des marchandises reçues », c'est-à-dire que le système paie automatiquement les volumes reçus, indépendamment de ce qui a été commandé ou facturé. Il ne procède pas à une triple concordance et ne fixe aucune tolérance. Là encore, les deux sociétés utilisent SAP, mais ces deux configurations entraînent des risques très différents, et les audits des SI différeront aussi largement entre l'une et l'autre.

Un éventail de variables

D'autres variables jouent sur la théorie du flocon de neige :

- Le degré de centralisation du système.
- Le degré de centralisation géographique.
- Le nombre de serveurs.
- Le choix des technologies d'infrastructure.
- Le degré de personnalisation.
- La structure organisationnelle du département informatique.
- Les versions de la technologie utilisée (Windows 2000 ou Windows 2003).
- Le degré et la méthode d'externalisation
- La politique de l'entreprise (on conserve tous les e-mails indéfiniment ou on n'en conserve aucun).

Toutes ces variables donnent la théorie du flocon de neige : il n'existe pas deux environnements de SI semblables. Il est donc très difficile, voire impossible, d'adopter une approche par checklist pour la planification et l'exécution des audits des SI. Chaque entreprise doit élaborer un plan d'audit des SI unique, répondant à ses risques propres.

Toute la difficulté consiste naturellement à identifier les risques métiers et liés aux SI propres à l'environnement du SI de l'organisation. C'est pourquoi le processus d'évaluation des risques liés aux SI joue un rôle vital, peut-être plus encore que l'évaluation globale des risques. De plus, ce sont des collaborateurs compétents qui doivent mener à bien l'évaluation des risques, par exemple ceux qui comprennent comment l'emploi d'Active Directory influera sur les audits des SI qui devront être effectués.

4.2 Évolution des risques

Selon la théorie du flocon de neige, chaque entreprise présente un profil de risque qui lui est propre. Cependant, il faut aussi tenir compte d'une autre dimension du risque : son évolution. Selon la loi de Moore de 1965, la densité des données sur un circuit intégré double tous les 18 mois. Dans les faits, cela signifie que les progrès technologiques sont rapides, ce qui ne surprendra personne.

Par conséquent, les risques liés aux SI ne sont pas statiques. Étant donné la forte croissance et l'expansion de la technologie, ils évoluent, parfois considérablement, d'une année sur l'autre. Il arrive même que le calendrier d'audit des SI repose sur une évaluation des risques efficace, mais au moment où les audits sont réellement effectués, ce profil de risque a tellement évolué, que les audits prévus ne sont plus suffisants.

Pour éviter ce problème, le responsable de l'audit interne doit :

- Reconnaître la nature dynamique du risque lié aux SI et mener des évaluations indépendantes de ce risque tous

les ans.
- Comprendre les plans à court terme du département informatique pour une année donnée et déterminer quelles peuvent en être les conséquences sur l'évaluation du risque lié aux SI.
- Commencer chaque audit des SI en actualisant l'évaluation du risque de cet audit.
- Faire preuve de souplesse vis-à-vis de l'univers de l'audit des SI ; surveiller le profil de risque de l'organisation et être prêt à adapter les procédures d'audit à son évolution.

4.3 Prolifération du risque lié aux SI

La troisième dimension à prendre en compte lorsque l'on évalue le risque lié aux SI est le concept de prolifération, qui désigne la nature additionnelle de ce risque. Supposons que l'organisation ait identifié le risque SI A et le risque SI B. Il se peut que chaque risque soit en soi faible, mais ensemble les deux processus se conjuguent et créent un risque SI C qui est nettement plus important que la somme des deux risques initiaux.

Exemple : L'entreprise XYZ utilise des applications Oracle. Elle ne dispose d'aucun processus pour surveiller l'activité de son système. De plus, tous les administrateurs système ont pleinement accès au système. Indépendamment, chaque élément représente un risque, mais, ensemble, ils forment une situation dans laquelle un certain nombre de personnes peuvent faire ce qu'elles veulent sur le système (autoriser des factures, rédiger des chèques, créer de nouveaux comptes de paye) sans aucun contrôle de détection. Dans ce cas, pour appréhender le véritable risque, il importe de comprendre les processus de gestion et de pilotage des SI, ainsi que le dispositif de sécurité propre au système.

Pour cette raison, il faut considérer le risque lié aux SI dans sa globalité et non isolément. Le responsable de l'audit interne doit le replacer au niveau de l'entreprise, évaluer non pas seulement chaque risque distinct, mais aussi les interactions entre ces différents risques. N'oubliez pas que l'environnement de SI compte plusieurs couches. Imaginez quelqu'un en train de faire passer du sable à travers plusieurs tamis empilés les uns sur les autres. Même si chaque tamis a des trous, la superposition des tamis empêche le sable d'arriver jusqu'en bas. Imaginez maintenant que chaque tamis comporte un petit trou, directement aligné sur un autre juste en-dessous. Dans ce cas, le sable passera sans aucune difficulté à travers tous les tamis.

Un bon responsable de l'audit interne tient toujours compte de toutes les couches de l'environnement de SI lorsqu'il planifie ou exécute des audits des SI. Il est très important d'évaluer les conséquences des risques à un niveau sur les risques aux autres niveaux.

4.4 Types de risques liés aux SI

La première étape pour comprendre les risques associés aux SI consiste à identifier ce qui peut poser problème :

- Disponibilité : le système n'est pas disponible pour utilisation.
- Sécurité : accès non autorisé au système.
- Intégrité : données incomplètes ou inexactes.
- Confidentialité : l'information n'est pas conservée secrète.
- Efficacité : le système ne procure pas une fonction voulue ou attendue.
- Efficience : le système entraîne une utilisation sous-optimale des ressources.

Les différents risques liés aux SI peuvent généralement être regroupés dans deux grandes catégories : risque « pervasif » et risque spécifique.

Risque « pervasif »

Certains risques liés aux SI ne sont pas limités à un système ou à un processus spécifique. Ces risques ont une incidence sur l'ensemble de l'entreprise, et sont par conséquent appelés risques « pervasifs ». Exemple : L'entreprise XYZ est reliée à Internet et n'a pas mis en place de pare-feu. Sur quel compte cela a-t-il une incidence ? Potentiellement sur tous et potentiellement sur aucun. Autre exemple : la présence de gicleurs d'eau dans le centre de calcul. Si ceux-ci se déclenchent intempestivement et aspergent d'eau tous les serveurs, quels processus opérationnels seront touchés ? Tous les processus, aucun ou tous les cas de figure entre les deux.

Risque spécifique

Le risque spécifique peut être directement lié à un processus ou à un compte spécifique. Considérez les paramètres de configuration de la triple concordance évoqués dans l'introduction au présent guide. S'ils sont mal configurés, le risque portera sur les créances fournisseurs et la trésorerie.

Pour les responsables de l'audit interne, les risques « pervasifs » sont plus dangereux pour l'entreprise que les risques spécifiques, mais très difficiles à quantifier. En outre, lorsque l'on fait état d'une faille du contrôle relatif à un risque « pervasif », il est beaucoup plus difficile de la relier son impact métier.

C'est l'importance qui est ici en jeu. Le responsable de l'audit interne ne doit pas oublier que les risques « pervasifs » et spécifiques sont importants et attirer l'attention sur ces deux catégories de risques. Si un examen de l'univers d'audit planifié ne montre pas que les audits couvrent les deux, il est probable que l'univers de l'audit des SI ne couvrira pas non plus correctement les risques auxquels l'organisation est confrontée.

4.5 Évaluation des risques liés aux SI

L'auditeur doit utiliser une technique ou une approche de l'évaluation des risques appropriée lorsqu'il élabore le plan global d'allocation des ressources d'audit des SI. L'évaluation des risques sert à examiner les unités auditables de l'univers d'audit et de sélectionner les zones à examiner qui présentent l'exposition au risque la plus forte. Les risques associés à

chaque couche ne peuvent pas être déterminés par un examen des risques liés aux SI pris isolément, mais doivent être considérés dans le cadre des processus et des objectifs de l'organisation.

Impact vs probabilité

L'évaluation des risques liés aux SI doit également tenir compte de leur impact et de leur probabilité d'occurrence. Ces risques ont souvent de graves conséquences, en particulier les risques « pervasifs ». La probabilité peut être plus difficile à déterminer car c'est une valeur de prévision (par exemple : quelle est la probabilité qu'un pirate informatique s'introduise dans le site Web de l'organisation ?). L'expérience passée et les bonnes pratiques générales peuvent étayer ces estimations. Le produit de l'impact et de la probabilité permet de définir la gravité du risque, qui donne une base pour comparer et hiérarchiser les risques liés aux SI.

Imaginons la société XYZ, qui a installé Windows 2003. Est-ce que ce système doit faire partie de l'audit des SI de cette année ? Comme souvent quand il s'agit des SI, la réponse est « ça dépend ». De multiples facteurs ont une incidence sur la décision. L'élément le plus important à prendre en compte est le risque et les conséquences de cette technologie sur les opérations de l'organisation. Si la seule application fonctionnant sous Windows 2003 est celle qui met à jour les codes postaux lorsque la poste les modifie, alors, il est clair que la technologie a une incidence très limitée sur l'intégrité globale des opérations de l'organisation. Par conséquent, on gaspillerait des ressources d'audit des SI si l'on s'amusait à auditer ce système. En revanche, si les systèmes de la chaîne d'approvisionnement primaire de l'organisation fonctionnent sous Windows 2003, alors, la technologie a bel et bien une incidence sur la réalisation des objectifs de l'organisation et doit être incluse dans le plan d'audit des SI.

Bien souvent, la réponse n'est toutefois pas aussi évidente. Pour que l'audit des SI soit efficace, il est donc nécessaire de procéder à une solide évaluation des risques liés aux SI. Celle-ci permet de remédier aux problèmes soulevés par la théorie du flocon de neige et de déterminer les zones sur lesquelles l'attention de l'audit doit se concentrer.

Évaluations traditionnelles des risques : à éviter

Il est important de noter que l'évaluation traditionnelle des risques risque de ne pas contribuer à une évaluation efficace des risques liés aux SI. Ces processus et ces tâches doivent être restructurés afin de satisfaire aux besoins d'une évaluation des risques SI. En particulier, la plupart des processus d'évaluation existants reposent largement sur des interviews. Or, ces dernières sont à elles seules loin d'être suffisantes pour évaluer le risque lié aux SI, car celui-ci est en grande partie fonction de la manière dont la technologie est configurée dans l'organisation en question. En outre, le risque lié aux SI dépend dans une large mesure de problématiques émergentes. Supposons, par exemple, qu'un pirate informatique découvre une nouvelle faille dans Windows 2003 et conçoive un outil qui exploite cette faille. Microsoft identifie le problème et produit un patch qui élimine la faille. Un auditeur des SI doit comprendre l'information concernant les patchs installés avant de pouvoir évaluer correctement le risque véritable que comporte cette technologie.

Risque statique et risque dynamique

À la section 4.4, nous nous sommes intéressés aux concepts de risque « pervasif » et de risque spécifique. Il est important de comprendre cette dynamique, mais, lorsque l'on évalue les risques liés aux SI, il importe également de tenir compte des risques statique et dynamique.

Risque statique – Le risque statique n'évolue guère d'une année sur l'autre et provient généralement du secteur dans lequel l'organisation opère. Par exemple, la société XYZ vend des livres en ligne. Le risque est associé à ses serveurs Web qui pilotent le système de commande en ligne. Si ces serveurs ne fonctionnent plus, les rentrées d'argent cessent jusqu'à ce que les serveurs soient remis en marche.

Lorsque l'on évalue le risque statique, les techniques d'enquête et d'interview sont, dans bien des cas, suffisantes. Par ailleurs, ces évaluations doivent être actualisées chaque année pour tenir compte de l'évolution des conditions, mais restent globalement valables d'une année sur l'autre. Sauf si la société XYZ décidait d'arrêter de vendre des livres en ligne et ouvrait un magasin, les serveurs Web continueront de représenter une zone à haut risque.

Risque dynamique – Le risque dynamique évolue sans cesse. Il est moins tributaire du secteur et davantage lié à l'évolution technologique (cf. la loi de Moore). La découverte d'une nouvelle faille dans Windows 2003 constitue un excellent exemple de risque dynamique. L'évaluation des risques effectuée l'an dernier n'aurait pas identifié ce risque, car il n'existait pas alors. Le risque dynamique a également une incidence sur la manière dont l'évaluation des risques liés aux SI doit être menée. Dans ce cas, l'évaluation doit se concentrer sur le processus mis en place par le département informatique pour piloter les patchs et mesurer la rapidité avec laquelle ils sont introduits.

La législation et la réglementation induisent elles aussi d'importants risques dynamiques. Elles ont des conséquences sur tous les pans de l'entreprise, mais, étant donné l'évolution technologique, elles gagnent en importance chaque année. Citons par exemple toutes les nouvelles règles et les nouveaux règlements concernant le respect de la confidentialité des informations relatives au consommateur qui ont été adoptés récemment.

Évaluation du risque dynamique

Lorsque l'on évalue le risque dynamique, les procédures d'enquête seront probablement insuffisantes à elles seules. Il

convient de suivre deux étapes clés :

Découverte – La découverte consiste à déterminer quelles technologies ont été déployées, comment elles ont été configurées et quels processus elles supportent et sur lesquels elles sont alignées. Dans bien des cas, des outils servent à soutenir le processus de découverte. Ainsi, une organisation dont le département informatique est décentralisé peut ne pas savoir combien de serveurs et de versions des systèmes d'exploitation sont utilisés à l'échelle de l'entreprise. Un outil de découverte et de cartographie du réseau peut permettre de collecter ces données rapidement et de façon précise.

Analyse – L'analyse repose sur l'évaluation des données une fois qu'elles ont été collectées. Là encore, cette évaluation ne s'appuiera vraisemblablement pas sur des enquêtes, mais sur l'analyse des données collectées par l'auditeur des SI au regard des nouveaux problèmes et risques technologiques.

Le concept de dépendance des risques apparaît lui aussi lors de la phase d'analyse. Nous l'avons déjà évoqué à l'aide de l'analogie du sable que l'on fait passer à travers une pile de tamis (section 4.3, prolifération du risque lié aux SI). S'il y a un trou dans chaque tamis, le sable peut s'écouler jusqu'en bas. C'est l'illustration de la dépendance des risques : les conséquences d'un risque donné peuvent dépendre de la présence d'autres risques. Ainsi, la société XYZ n'a pas isolé le réseau général et utilise plusieurs réseaux sans fil. L'équipe d'ingénieurs travaille de façon collaborative par voie électronique aux avant-projets sur les nouveaux produits. Dans ce cas, le risque pour l'entreprise est qu'un concurrent, posté à l'extérieur avec un dispositif d'écoute, capte ces informations. Ce risque provient de la combinaison de la conception des réseaux et des processus, ainsi que des nouvelles technologies, et chaque risque dépend de l'existence des deux autres. Le risque total est plus grand que la somme des différents risques considérés individuellement.

C'est la raison pour laquelle de nombreuses organisations recourent à une stratégie reposant sur des « couches de défense », qui consiste à mettre en place de multiples couches de sécurité et de contrôle. Il est important que, pendant le processus d'analyse, le responsable de l'audit interne évalue la conception et l'efficacité de toutes les couches de défense avant de tirer ses conclusions sur l'impact d'un risque ou d'une faille des SI.

Évaluation robuste du risque lié aux SI

Le responsable de l'audit interne doit élaborer un plan en conséquence et veiller à ce que le processus d'évaluation des risques liés aux SI :

- Soit mené en profondeur chaque année et ne soit pas une simple mise à jour par rapport à l'année précédente.
- Tienne compte de toutes les couches de l'environnement de SI.
- Tienne compte des risques statiques et dynamiques.
- Ne repose pas uniquement sur des interviews, mais recoure à d'autres techniques de découverte.
- Soit complété par le niveau d'analyse approprié après la découverte.
- Soit effectué par le personnel compétent.

Ce dernier point est celui qui risque de poser l'un des principaux problèmes aux responsables de l'audit interne, car le SI est un concept très large qui comporte de nombreuses couches. Les compétences requises pour comprendre chaque couche sont très différentes. Les compétences techniques très pointues d'un spécialiste des réseaux ne sont en rien comparables à celles d'un spécialiste des applications SAP. Pour que l'évaluation des risques liés aux SI soit efficace, il faut faire appel à des spécialistes qui comprennent toutes les couches de l'environnement de SI. Il est rare, si ce n'est impossible, de trouver toutes ces compétences réunies au sein d'une seule et même personne. Il sera nettement plus facile de constituer une équipe de spécialistes de l'audit des SI dont les compétences couvrent toutes les couches nécessaires. Cette équipe devra également travailler en étroite collaboration durant tout le processus, en premier lieu en raison du problème de dépendance des risques.

Une fois l'évaluation des risques liés aux SI effectuée avec le niveau de précision requis, il convient de déterminer quels audits des SI doivent être réalisés. Si l'évaluation des risques SI a été effectuée de façon efficace, l'organisation aura une idée raisonnable des risques liés aux SI. Cependant, cela pose aussi un certain nombre de problématiques, notamment celui de la définition des audits des SI.

Dans l'exemple précédent (page 9), l'entreprise a identifié un risque métier,lié à la disparition de l'organisation d'informations importantes relatives à la conception du produit. Quel audit permet d'analyser ce risque ? Faut-il procéder à un audit des réseaux sans fil, à un audit de l'architecture et de la conception des réseaux ou bien à une revue de l'application de conception électronique ? Et si les audits sont ainsi dissociés, il y a fort à parier que les constats d'audit porteront sur des paramètres techniques pour chaque technologie concernée. Cependant, le comité d'audit se moque vraisemblablement des paramètres techniques détaillés et souhaite plutôt que les constats de l'audit des SI mettent en évidence les dysfonctionnement de l'organisation.

Par conséquent, la façon dont les audits des SI sont définis joue un grand rôle dans l'efficacité globale de la fonction d'audit des SI. D'autant que cette dernière doit travailler en collaboration avec les auditeurs des processus/des opérations/des finances et tenir compte des procédures qu'ils mettent en œuvre, en particulier dans des environnements comportant de vastes applications ERP intégrées, où un grand nombre de contrôles clés sont intégrés aux systèmes.

Même s'il n'existe pas de bonne façon de définir les audits des SI, il en existe de plus ou moins mauvaises. Ainsi, de nombreux responsables de l'audit interne font l'erreur de définir le périmètre d'audit des contrôles généraux des SI. Ce périmètre est tellement vaste que cela ne veut quasiment plus rien dire, en particulier dans une grande organisation. Les commutateurs téléphoniques sont-ils inclus ? Qu'en est-il de la configuration des ordinateurs de bureau ? Des contrôles de l'environnement dans le centre de données ? De tous les éléments ci-dessus ? Si tout est inclus, l'audit prendra beaucoup de temps.

5.1 Conseils à l'intention du responsable de l'audit interne

La difficulté consiste à conférer le bon niveau de granularité à la définition de l'univers de l'audit des SI, de manière à ce que celui-ci soit efficace et efficient. Ce niveau sera différent pour chaque fonction de l'audit des SI (extension de la théorie du flocon de neige), mais voici ce dont le responsable de l'audit interne doit tenir compte dans la définition des audits des SI :

- **L'utilisation de définitions trop larges pour les audits des SI (par exemple, contrôles généraux des SI) entraîne presque toujours un glissement de périmètre.** En outre, il peut également y avoir un écart entre ce sur quoi le management pense que porte l'audit et les procédures d'audit effectivement mises en œuvre. Par exemple, la société XYZ installe une application SAP pour ses processus comptables. Le département d'audit des SI effectue une revue post-mise en place des contrôles configurables portant sur les créances fournisseurs, mais il la nomme « revue post-mise en place SAP ». Après l'audit, la société rencontre un gros problème concernant la configuration de la sécurité des utilisateurs SAP. Le comité d'audit demandera certainement pourquoi cette configuration n'a pas été prise en compte dans la revue SAP post implantation. La réponse est qu'elle n'a pas été évaluée. Mais la formulation de l'audit était trompeuse. Sachant cela, les responsables de l'audit interne doivent veiller à ce que la définition de chaque audit des SI donne une description juste et précise des éléments examinés.
- **L'univers d'audit pour l'année doit porter sur toutes les couches de l'environnement de SI.** Même si chaque environnement d'audit des SI est différent, les couches sont généralement identiques. Si le plan d'audit des SI n'inclut pas une revue de chaque couche, il y a de fortes chances que le plan dans son ensemble soit déficient.
- **Les audits des SI doivent être structurés de manière à permettre une communication efficace et logique.** Les revues d'applications, par exemple, sont rarement optimales lorsqu'elles sont menées séparément (par exemple une revue de la comptabilité fournisseur sous Oracle). Les applications doivent être intégrées à partir d'un processus d'exécution et de communication aux audits des processus/des opérations/financiers. Les audits des SI portant sur des technologies présentes dans toute l'organisation (réseaux, processus, etc.) sont généralement plus efficaces s'ils sont menés au niveau de l'entreprise. En d'autres termes, évitez de mener un audit des réseaux sur le site de Pittsburgh et un autre sur celui de Phoenix par exemple. N'effectuez qu'un seul audit des réseaux de l'entreprise. La géographie importe moins que le processus.
- **Les audits des SI doivent porter sur les bons risques.** Dans bien des cas, le budget des audits des SI est fixé avant que l'évaluation des risques liés aux SI ne soit effectuée. Cela conduit inévitablement à l'une des deux situations suivantes :
    1. Un nombre d'heures insuffisant est réparti sur un trop grand nombre d'audits, d'où des audits des SI de qualité toujours médiocre car il n'y a pas assez de temps pour les mener correctement.
    2. Des audits qui doivent être réalisés ne le sont pas parce que le budget ne le permet pas.

La planification et le budget de l'audit des SI doivent être déterminés à l'issue de l'évaluation des risques liés aux SI, et non avant. De même, cette évaluation des risques SI doit être considérée dans le contexte de l'évaluation globale des risques de l'entreprise. Il est tout à fait possible que, dans une organisation donnée, l'environnement de SI induise tellement de risques que tous les audits internes réalisés pour l'année doivent être des

audits des SI, une situation à l'évidence extrême, mais pas impossible.

5.2 Définir le budget de l'audit des SI

L'un des erreurs les plus courantes commises par un responsable de l'audit interne lorsqu'il définit l'univers de l'audit des SI est de sous-estimer le temps nécessaire pour réaliser un audit des SI. On aboutit dans bien des cas à la théorie du flocon de neige. Exemple : la société ABC utilise une application financière sur un AS/400. L'auditeur SI veut évaluer la sécurité afférente à l'AS/400, et il y passe 100 heures. La société XYZ utilise elle aussi une application similaire sur un AS/400. L'examen prendra-t-il autant de temps ?

La réponse est bien entendu « ça dépend ». Si la société ABC compte 100 utilisateurs et la société XYZ 1 000 utilisateurs, on peut supposer qu'il faudra 10 fois plus de temps pour cette dernière si l'audit doit évaluer tous les utilisateurs. Si l'audit ne porte que sur les droits d'accès d'un échantillon de 10 utilisateurs, alors, les audits prendront autant de temps, mais procureront des niveaux d'assurance différents.

Cet exemple montre combien il est dangereux d'estimer le budget de l'audit des SI. Il est facile de se faire une idée très éloignée de la réalité, ce qui ne se produit généralement pas pour les audits opérationnels et financiers, dont les estimations peuvent être erronées, mais pas de façon conséquente.

Autre exemple : l'audit d'un système SAP. Une revue portant sur la sécurité d'un système SAP ayant deux environnements de production clients prendra deux fois plus de temps que celui d'un système SAP n'ayant qu'un seul environnement de production client. Malheur au responsable de l'audit interne qui a estimé le budget sans comprendre pleinement l'environnement de SI (section sur l'évaluation du risque lié aux SI) ! Si les estimations n'ont pas tenu compte du nombre d'environnements clients en production, elles peuvent se révéler largement erronées.

Comment un responsable de l'audit interne doit-il faire face à ce problème ? À l'évidence, il est crucial de bien comprendre l'environnement de SI, ce que permettra naturellement une évaluation adéquate des risques liés aux SI. D'autre part, il est important d'estimer précisément le temps nécessaire aux différentes tâches à réaliser dans le cadre d'un audit des SI. Certaines de ces tâches, comme l'examen des paramètres d'une configuration, peuvent être menées avec rapidité et efficience. D'autres, comme l'audit d'une architecture sécurité utilisateur complexe, peuvent prendre beaucoup de temps. Tactiquement, un responsable de l'audit interne doit porter un regard critique sur les estimations de budget des audits programmés, veiller à ce que la planification préparatoire soit suffisante pour justifier une estimation et que le personnel et la direction du département d'audit des SI soient d'accord sur cette estimation. N'oubliez pas que, dans de très rares cas, un audit des SI de moins de 80 heures peut se révéler suffisant pour n'importe quelle technologie.

Le déroulement d'un audit des SI n'est théoriquement pas différent de celui d'un audit opérationnel. L'auditeur planifie l'audit, identifie et documente les contrôles, vérifie l'efficacité de la conception et du fonctionnement de ces contrôles, tire ses conclusions et rédige son rapport. La plupart des responsables de l'audit interne connaissant bien ce processus général, nous n'en parlerons pas ici. Cependant, un audit des SI diffère par certains aspects d'un audit traditionnel. C'est pourquoi, cette section définie certains de ces aspects et donne aux responsables de l'audit interne quelques pistes et conseils. Voir figure 2 ci dessous.

6.1 Cadres de référence et normes

L'une des difficultés que rencontrent leurs auditeurs lorsqu'ils effectuent un audit des SI est la détermination d'un point de comparaison. Nombre d'organisations ne disposent pas de références complètes pour toutes les applications et technologies. L'évolution rapide de la technologie rendrait ces références rapidement obsolètes et donc inutiles.

D'après la théorie du flocon de neige chaque environnement de SI est différent, mais cela ne doit pas nous faire perdre de vue les objectifs de contrôle. Ces derniers doivent, par définition, rester plus ou moins constants d'un environnement à l'autre. Considérons l'objectif selon lequel toutes les données et tous les programmes critiques métiers doivent faire l'objet d'une sauvegarde et d'une restauration. Chaque environnement peut s'en acquitter de manière très différente : les sauvegardes peuvent être manuelles ou automatisées, ou bien on peut utiliser un outil à cette fin. Elles peuvent être uniquement incrémentales ou bien on peut effectuer des sauvegardes complètes de chaque élément. Les sauvegardes peuvent être effectuées sur une base quotidienne, hebdomadaire, mensuelle, etc. Le stockage des sauvegardes peut se faire sur site dans un coffre ignifuge, hors site dans une autre société ou bien être sous-traité à un tiers. La méthode retenue par l'organisation pour la gestion de ses sauvegardes aura très certainement une incidence sur les procédures et sur le budget de l'audit, mais l'objectif de contrôle, lui, ne changera pas. Cela étant, un responsable de l'audit interne doit pouvoir commencer avec un ensemble d'objectifs de contrôle des SI, il doit pouvoir trouver un cadre de référence approprié même s'il n'est pas à 100 % adapté à son environnement.

COSO et COBIT

Où un responsable de l'audit interne peut-il trouver un ensemble complet d'objectifs de contrôle des SI ? Les cadres de référence *Contrôle interne et management des risques de l'entreprise* du Committee of Sponsoring Organizations of the Treadway Commission (COSO) constituent d'excellentes sources d'information, mais ils ne sont pas spécifiquement axés sur les SI. De plus, les SI ont considérablement évolué depuis 1992, date de la première publication du COSO, ce qui rend les objectifs de contrôle des SI du COSO moins pertinents pour les technologies actuelles. L'environnement de contrôle reposant sur le COSO doit être complété par des objectifs de contrôle des SI plus détaillés, qui permettront d'évaluer plus efficacement l'environnement de contrôle des SI. Il existe un certain nombre de possibilités à cet égard.

Le COBIT *(Control Objectives for Information and related Technology)*, publié au départ par l'Information Technology Governance Institute en 1994, avec le soutien de l'ISACA (Information Systems Audit and Control Association), est l'un des ces cadres de références de contrôle SI. La version 4.0 du COBIT a été publiée en novembre 2005. Le COBIT n'a pas pour intention de faire concurrence aux référentiels COSO, mais il peut les compléter par des objectifs de contrôle plus robustes et spécifiques aux SI. La version 4.0 contient 214 objectifs de contrôles SI détaillés, organisés selon 34 processus. À l'évidence, le COBIT propose une approche plus détaillée que le COSO et les cadres ERM, qui constituent néanmoins de bons points de départ pour identifier les objectifs de contrôle pertinents pour l'environnement audité.

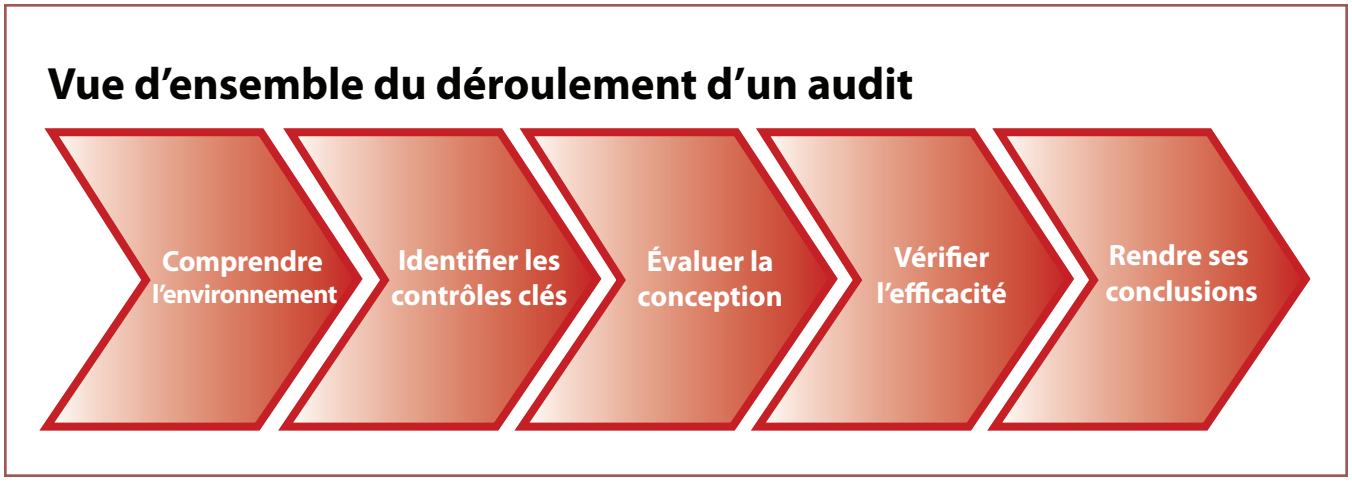

Figure 2 – Vue d'ensemble du déroulement d'un audit

Politiques, normes et procédures

Un cadre comme le COBIT propose un ensemble d'objectifs de contrôle des SI accepté par tous, qui aide le management à conceptualiser une approche de la mesure et de la gestion des risques liés aux SI. Le management se sert généralement d'un tel cadre pour le développement d'un système complet de politiques, normes et procédures relatives aux SI.

Par exemple, un cadre de contrôle des SI fonctionnel doit comporter un objectif de contrôle relatif à la protection des systèmes d'information contre l'accès non autorisé. Une organisation peut y parvenir en définissant une politique précisant que, pour accéder à tous les systèmes de production, il faut un identifiant et un mot de passe utilisateur uniques. Cette politique peut ensuite être complétée par une norme organisationnelle qui définit les spécifications obligatoires de l'identifiant et du mot de passe (par exemple, les identifiants sont la première lettre du prénom de l'utilisateur et son nom de famille ; le mot de passe doit comporter au moins huit caractères et se composer de lettres et d'autres caractères ; etc.). Cette norme sera ensuite complétée par des procédures définissant la mise en œuvre des normes plateforme par plateforme et spécifiant la « preuve de contrôle » créée et conservée après la mise en œuvre réussie de la procédure. Cette approche en cascade depuis le cadre de contrôle jusqu'aux politiques, normes et procédures est ce qui permettra de faire correspondre les contrôles des SI à l'environnement de contrôle de l'entreprise et métier.

Supposons que, dans l'exemple ci-dessus, l'organisation n'a pas défini de normes précisant la longueur des mots de passe, etc. Dans ce cas, le responsable de l'audit interne devra trouver une base de référence pour l'audit, ce qui aboutit souvent à un débat avec le management des SI sur la définition d'un contrôle suffisant. Lequel est le plus sûr : un mot de passe d'une longueur minimum de six caractères qui expire au bout de 30 jours, ou un mot de passe d'une longueur minimum de huit caractères qui expire au bout de 90 jours ? On fait souvent référence aux « bonnes pratiques », mais on ne les met pas toujours en relation avec la situation.

En l'absence de normes de contrôle des SI spécifiques à l'organisation, il existe diverses normes disponibles dans le commerce ou utilisées dans le secteur. Elles peuvent constituer un ensemble de recommandations de « bonnes pratiques » lorsqu'elles donnent des détails (par exemple, un mot de passe doit comporter au moins huit caractères et expirer au bout de 60 jours). Un auditeur des SI peut s'appuyer sur ces normes et s'en servir de référence pour son audit. Ces normes permettent également de signaler des déficiences d'une manière non subjective. Comparez les deux énoncés suivants : « La sécurité des mots de passe peut être améliorée » et « Les mots de passe ne respectent pas la norme ISO 27 001 sur la sécurité de l'information ». Il est évident que la seconde formulation suscitera moins de débats.

La difficulté lorsqu'on choisit de mener un audit en prenant les normes publiques comme référence, c'est qu'il existe beaucoup de normes différentes et qu'elles ne recommandent pas toutes la même chose. L'objectif du présent guide n'est pas de débattre des avantages des différentes normes, mais simplement d'inciter le responsable de l'audit interne à utiliser des normes pour ses audits des SI, celles qui sont les plus pertinentes pour l'organisation et acceptables aux yeux du management des SI. Dans la plupart des cas, une norme fait référence à un élément très précis de l'environnement de SI, comme la sécurité ou le développement d'un programme spécifique. La plupart du temps, le responsable de l'audit interne n'est pas en mesure d'imposer la norme à utiliser par l'organisation. Cette décision est du ressort des SI ou de la direction. Si une norme a déjà été acceptée et déployée, le responsable de l'audit interne doit la repérer et mener son audit en y faisant référence. Il a également l'obligation d'évaluer le caractère globalement suffisant des normes retenues par le management des SI pour faire en sorte qu'elles soient en conformité avec le profil de risque, les besoins et les impératifs réglementaires à respecter par l'organisation.

Six sources de normes

Certaines normes doivent être prises en considération :

- **ISO 27001/ISO 17799** – L'Organisation internationale de normalisation (ISO) a édité une norme générique sur la sécurité des SI reconnue à l'échelle internationale. Il s'agissait au départ d'une norme britannique (BS 7799), qui a été transformée en norme ISO (ISO 17799), et qui est désormais connue sous l'appellation ISO 27001. Elle présente les bonnes pratiques acceptées par tous concernant la gestion de la sécurité des SI et constitue un document de référence utile à partir duquel les auditeurs des SI peuvent mener à bien leurs missions. http://www.iso.org
- **Capability Maturity Model Integration** – Le Software Engineering Institute (SEI) de l'université Carnegie Mellon publie des Capability Maturity Models (CMM, modèles de maturité des capacités) relatifs à différents processus au sein d'une organisation, principalement liés au déploiement de logiciels. Citons par exemple le Systems Engineering CMM (CMM de l'ingénierie systèmes) et le Software Acquisition CMM (CMM d'acquisition des progiciels). Ces CMM proposent un modèle permettant d'élaborer des processus maîtrisés utilisables sur la durée au sein d'une organisation et sont utiles aux auditeurs des SI qui auditent des processus de développement des systèmes. En 2005, le SEI a intégré les différents CMM existants pour un Capability Maturity Model Integration (CMMI). http://www.sei.cmu.edu/cmmi/general/general.html
- **National Institute of Standards and Technology (NIST)** – Le Computer Security Resource Center est une division du NIST qui propose une série complète de publications offrant des informations détaillées sur le contrôle de la sécurité des SI. Citons, comme exemples de ses publications, *Biometric Data Specification for Personal Identity Verification*

et *Guidance for Securing Microsoft XP for IT Professionals.* Ces normes, incontournables pour tout auditeur des SI travaillant dans le secteur public, l'aérospatiale ou la défense, détaillent les bonnes pratiques, qui peuvent également être appliquées dans d'autres secteurs. http://csrc.nist.gov/publications/nistpubs/index.html

SysAdmin, Audit, Network, Security (SANS) Institute – Source d'information parmi les plus fiables au monde pour ce qui est de la formation et de la sensibilisation à la sécurité des TI (et de loin la plus importante), le SANS Institute publie de nombreux documents traitant des différents aspects de la sécurité pour diverses technologies. Les publications du SANS exposent un certain nombre de critères incontournables au regard desquels l'auditeur des SI peut effectuer son audit. http://www.sans.org/aboutsans.php

L'IT Infrastructure Library (ITIL) – Soutenu par le British Standards Institute, l'ITIL édite les bonnes pratiques sur lesquelles peuvent s'appuyer les services informatiques. Ses publications portent essentiellement sur le management des services informatiques. Elles constituent donc un outil précieux pour les auditeurs internes qui auditent le management des SI. http://www.itil.co.uk/

Normes spécifiques aux fournisseurs – De nombreux fournisseurs de solutions technologiques publient des recommandations sur la sécurité et le contrôle applicables à la technologie qu'ils produisent. SAP, par exemple, édite un guide sur la sécurité en trois volumes, qui énonce des recommandations détaillées pour la sécurité et les contrôles de l'application SAP ERP. Souvent, ces normes fournisseurs ne prennent pas en compte la sécurité et le contrôle au même niveau que, par exemple, une publication NIST, mais elles donnent une bonne base de départ. Elles peuvent également contribuer à resserrer le débat autour de certains constats (par exemple : « les restrictions de mot de passe SAP ne sont pas fixées conformément aux exigences de sécurité définies par le fournisseur »). Les responsables de l'audit interne doivent donc vérifier auprès des fournisseurs de systèmes critiques pour les missions si des normes spécifiques sont disponibles. Dans bien des cas, les fournisseurs n'ont rien publié, mais le groupe d'utilisateurs associé à cette technologie a édité une ou des publication(s) (c'est par exemple le cas de l'ASUG, le groupe d'utilisateurs de SAP aux États-Unis).

6.2 Gestion des ressources d'audit des SI

Les ressources consacrées à la réalisation des missions planifiées jouent un rôle crucial dans l'efficience et l'efficacité des audits. Les SI englobent un large éventail de technologies, et les compétences requises pour auditer la configuration d'un pare-feu sont très différentes de celles nécessaires pour auditer les tables de triple concordance des créances fournisseurs dans les applications Oracle. Pour un audit donné requérant telles ou telles compétences, il est donc essentiel de trouver l'auditeur adéquat.

Aujourd'hui, les responsables de l'audit interne ont du mal à trouver, embaucher et garder des professionnels compétents de l'audit des SI. Inévitablement, toute discussion à ce propos se cristallisera sur la question de savoir s'il faut embaucher un informaticien et lui apprendre comment procéder à un audit ou s'il est préférable d'embaucher un auditeur et de lui enseigner les SI. Aucune solution n'est idéale, et l'on trouvera toujours des exceptions, mais globalement, le responsable de l'audit interne doit partir du principe qu'aucun auditeur des SI ne sera à même de réaliser tous les types d'audit informatique. C'est pourquoi une fonction d'audit des SI devra disposer d'auditeurs experts en applications informatiques et d'autres plus spécialisés dans les technologies d'infrastructure. Si l'organisation a besoin d'un auditeur plus compétent en applications informatiques, il est généralement plus efficace de trouver une personne spécialisée dans la finance, les processus ou l'audit et de la former à une application informatique particulière. En revanche, si elle a besoin d'un auditeur s'y connaissant davantage en audit des technologies d'infrastructure, il serait plus efficace d'embaucher un informaticien et de le former à l'audit. Par conséquent, un responsable de l'audit interne qui maîtrise l'univers de l'audit des SI ainsi que les compétences requises dont il dispose au sein de son équipe, doit être à même de cibler ses efforts de recrutement en conséquence.

Stratégie pour retenir les auditeurs des SI

Une fois les auditeurs SI embauchés, la principale difficulté consiste à les garder. Ils ont en effet tendance à être plus mobiles que les auditeurs classiques en raison de la pénurie actuelle d'auditeurs compétents dans leur spécialité sur le marché du travail. L'une des solutions qui s'offrent au responsable de l'audit interne consiste à mieux les rémunérer. Mais souvent, des contraintes budgétaires interdisent ce choix, et le responsable de l'audit interne doit alors faire preuve d'imagination dans sa stratégie de rétention.

De nombreux auditeurs SI sont motivés par la confrontation aux technologies. Ils aiment manipuler des technologies nouvelles et passionnantes. Voici quelques aspects qui peuvent aider à retenir un auditeur SI en faisant valoir son désir d'être confronté aux technologies :

Certifications – Il existe un certain nombre de certifications informatiques spécifiques. Il peut s'agir de certifications techniques (par exemple diverses certifications dans des technologies de bases de données et de routeurs Cisco) ou de certifications dans des modules spécifiques de SAP. L'ISACA, par exemple, propose une certification CISA (Certified Information Systems Auditor). L'ITIL Foundation Certification atteste d'un minimum de compréhension des divers processus ITIL pour la gestion et la prestation de services. Elle est incontournable pour les auditeurs SI

qui auditent des départements informatiques utilisant les processus ITIL.

Le responsable de l'audit interne peut envisager d'accorder des primes pour des certifications de haut niveau très recherchées : ainsi, un auditeur SI peut recevoir une prime spéciale pour devenir « Cisco Certified Network Associate » (CCNA). Cette méthode permet à l'organisation d'offrir un supplément de rémunération sans avoir à relever le salaire de base. En outre, la plupart des certifications sont assez longues à obtenir, ce qui garantit que l'auditeur restera au moins le temps nécessaire à l'obtention de sa certification. Cela étant, certains auditeurs SI collectionnent les certifications dans l'optique de sortir de leur fonction d'audit. Il convient donc d'examiner avec attention les certifications que l'auditeur souhaite obtenir et de s'assurer qu'elles peuvent s'intégrer dans l'univers d'audit des SI prédéfinis.

Rotation – On peut envisager un programme de rotation entre le département informatique et le service d'audit des SI. Cette méthode peut contribuer à renforcer les compétences de l'audit des SI et à resserrer les liens avec le département informatique lors des missions d'audit. Lorsque l'on choisit cette stratégie, il faut prendre garde aux éventuels problèmes de dépendance. Il faut également être sûr que la fonction d'audit des SI a une expertise d'audit à apporter aux informaticiens qui rejoignent ses rangs lors de ces rotations.

Formation continue – Les auditeurs SI ont besoin de davantage de formation que les auditeurs spécialisés dans les processus et l'opérationnel. Si les processus de triple concordance n'ont guère avancé au cours des dix dernières années, on ne peut pas en dire autant des SI. Pour se tenir au courant, les auditeurs SI doivent se former régulièrement et aussitôt qu'ils entrent dans la vie active. Le responsable de l'audit interne doit bien en avoir conscience et élaborer, pour le département, une stratégie de formation qui tienne compte des besoins des auditeurs SI. Il faut chercher à renforcer l'expertise dans de multiples sujets importants. Pour ce faire, on peut désigner tel ou tel auditeur des SI pour qu'il devienne expert d'une technologie donnée (par exemple, l'un des auditeurs des SI se spécialise dans Microsoft, un autre dans les bases de données et un troisième dans SAP). Cette manière de procéder aboutira à de meilleurs audits que si tous les auditeurs sont formés à tous les sujets, mais elle requiert davantage d'attention et de planification pour l'élaboration du plan de formation annuel dans l'audit des SI.

Groupes d'utilisateurs – La plupart des fournisseurs de solutions informatiques disposent d'un groupe d'utilisateurs, c'est-à-dire d'un ensemble de clients qui utilisent la technologie et s'associent pour mettre en commun des idées, des préoccupations et, l'espèrent-ils, influencer l'évolution future de la technologie. Même si, traditionnellement, les groupes d'utilisateurs sont la chasse gardée des informaticiens et des utilisateurs professionnels de l'informatique, dans bien des cas, ces groupes peuvent également être utiles aux auditeurs SI. L'Americas' SAP Users' Group (ASUG, groupe d'utilisateurs de SAP aux États-Unis), par exemple, dispose d'un sous-groupe qui se concentre sur la sécurité et les contrôles. Les auditeurs SI doivent donc trouver les groupes d'utilisateurs consacrés aux technologies utilisées par l'organisation et les rejoindre. Souvent, cette démarche n'induit pas de coût supplémentaire pour l'organisation. La plupart de ces groupes sont administrés par entreprise, et tous les salariés de l'entreprise y sont les bienvenus.

Un personnel adéquat

De nombreux services d'audit doivent s'accommoder de contraintes budgétaires. Celles-ci les empêchent de disposer d'une équipe qui aurait toutes les compétences d'audit des SI dont ils auraient besoin pour auditer efficacement l'ensemble de l'univers de l'audit des SI. L'organisation n'attendrait pas du département informatique qu'il fonctionne sans disposer en interne de personnel ayant toute l'expertise requise dans les systèmes d'exploitation, bases de données, réseaux et applications. Pourtant, elle attend parfois du service d'audit qu'il fonctionne sans les ressources suffisantes. Cette situation conduit inévitablement à procéder à des audits au moyen de listes de vérification et à utiliser des techniques d'enquête comme source primaire de preuves d'audit. Comme indiqué dans l'ensemble de ce document, pour que l'audit des SI soit efficace, un plan d'audit spécifique doit faire suite à une solide évaluation des risques et s'appuyer sur des procédures d'audit spécialement conçues pour s'adapter aux particularités de tel ou tel environnement. Le responsable de l'audit interne doit justifier auprès du management et du comité d'audit de l'enveloppe budgétaire qui lui permettra de disposer de toutes les compétences d'audit des SI nécessaires.

Aux États-Unis, si le responsable de l'audit interne doit s'efforcer d'obtenir des ressources suffisantes, c'est surtout en raison du paragraphe 140 de la norme d'audit no 2 du Public Company Accounting Oversight Board (PCAOB), intitulée *An Audit of Internal Control Over Financial Reporting Performed in Conjunction with An Audit of Financial Statements*, selon laquelle :

> « Les [circonstances] suivantes doivent être considérées au moins comme une déficience significative et un indicateur fort de l'existence d'une déficience matérielle importante *(material weakness)* dans le contrôle interne se rapportant à la communication financière. [...] L'audit interne ou la fonction d'évaluation des risques est inefficace alors que l'entreprise en aurait particulièrement besoin afin de disposer d'un pilotage ou d'une évaluation des risques performante, notamment s'il s'agit d'entreprises très grandes ou très complexes. »

L'auditeur externe d'une organisation pourrait conclure que le paragraphe 140 s'applique, par exemple, lorsque la fonction d'audit interne des SI est inexistante ou insuffisante alors que l'environnement de SI est vaste ou complexe.

Dans certains cas, les responsable de l'audit interne peuvent s'interroger sur l'opportunité de procéder à du co-sourcing (partage de prestation) pour tout ou partie de la fonction d'audit des SI. La plupart d'entre eux connaissent les avantages et les inconvénients de cette méthode, et ce guide n'entend pas s'étendre sur ce point. Cependant, les responsables de l'audit interne ont souvent du mal à définir dans quelles proportions et pour quels audits recourir au co-sourcing. Le dosage optimal varie d'une organisation à l'autre (la théorie du flocon de neige s'applique encore), mais les responsables d'audit interne pourront trouver quelque utilité à voir où se situe leur organisation par rapport aux données suivantes, tirées du rapport *Global Audit Information Network (GAIN)*, datant de 2004, de l'Institut d'audit interne (IIA) :

- 39 % de tous les achats de services d'audit interne ont un rapport avec l'audit des SI.
- Proportion de travaux d'audit des SI externalisés :
  - 8,1 % des organisations externalisent 100 % de leurs travaux d'audit des SI.
  - 7,1 % des organisations externalisent la majeure partie de leurs travaux d'audit des SI.
  - 8,3 % des organisations externalisent entre 25 et 50 % de leurs travaux d'audit des SI.
  - 33,1 % des organisations externalisent une partie de leurs travaux d'audit des SI.
  - 41,6 % des organisations n'externalisent pas du tout leurs travaux d'audit des SI.
- Stratégie pour les trois ans à venir :
  - 18,9 % des organisations envisagent d'accroître la proportion d'audit des SI externalisée
  - 64,9 % des organisations n'envisagent pas de modifier la proportion d'audit des SI externalisée.
  - 13,3 % des organisations envisagent de réduire la proportion d'audit des SI externalisée.

Autres suggestions pour le co-sourcing :

Co-sourcing des audits techniques – En l'occurrence, les « audits techniques » se réfèrent aux audits portant sur les couches applications et infrastructures techniques de l'environnement de SI. De manière générale, ces audits requièrent un niveau bien plus élevé d'expertise technique spécifique que l'on aura plus de chances de trouver sur le marché qu'en interne. Les audits des SI de la couche management sont bien plus axés sur les processus informatiques (par exemple le développement de systèmes) et nécessitent donc moins de compétences techniques pointues.

Envisager de faire appel à deux prestataires – Il peut être intéressant de conclure plusieurs contrats, avec un prestataire principal de services co-sourcés, ainsi qu'avec un prestataire secondaire. Dans certains cas, un cabinet d'audit peut, pour une raison ou pour une autre, se retrouver dans une situation de conflit d'intérêts vis-à-vis d'une mission d'audit, et il peut alors se révéler utile de disposer d'un second prestataire prêt à intervenir. Mais attention : le prestataire principal doit réaliser au moins 80 % des activités co-sourcées. En deçà, la baisse d'efficience (par exemple deux fois plus de réunions et une augmentation des frais administratifs) dépassera les avantages. Si l'on veut être sûr que les prestataires connaissent bien l'organisation et la considèrent comme un client important, il ne faut pas faire appel à plus de deux entreprises. Si le cabinet ABC fournit la majorité, voire la totalité des services d'audit des SI à une organisation, sa relation vis-à-vis de cette dernière ne sera pas la même que si elle est l'un des deux ou trois sous-traitants qui fournissent 30 % de ces services à l'organisation.

Co-sourcing des audits répartis à travers le monde – La plupart des entreprises emploient des salariés dans toutes les grandes régions de la planète, bien souvent avec des grilles de tarif différentes suivant les régions. En conséquence, si une organisation souhaite auditer ses opérations à Kuala Lumpur, elle peut faire appel à une société locale employant du personnel malaisien à un coût moindre, au lieu d'envoyer des collaborateurs en Malaisie. Une exception, cependant : lorsque la charte de l'audit interne prévoit que le département d'audit interne fournisse une certaine quantité de prestations de conseil au sujet des contrôles aux diverses unités de l'organisation. Dans ce cas, il peut être plus utile d'envoyer une équipe d'auditeur faire le tour des sites à l'étranger, de sorte que celle-ci puisse observer les bonnes pratiques internes et en faire profiter les autres unités.

Comme indiqué plus haut, les budgets d'audit des SI peuvent se révéler difficiles à estimer et à gérer. C'est pourquoi les responsables de l'audit interne doivent utiliser chaque fois que possible des accélérateurs, c'est-à-dire des outils et/ou des techniques venant appuyer les procédures exécutées par les auditeurs SI, en vue d'accroître l'efficience et l'efficacité de l'audit. Les responsables de l'audit interne peuvent utiliser un accélérateur pour réaliser le même audit en moins de temps, ou bien, réaliser un audit plus approfondi dans le même laps de temps.

Beaucoup d'accélérateurs d'audit requièrent un investissement, si bien que le responsable de l'audit interne doit soigneusement évaluer le rapport coût/avantages de toute solution avant de s'y engager. Les accélérateurs d'audit peuvent être répartis en deux catégories : les facilitateurs d'audit, qui étayent le management global de l'audit (par exemple un outil de gestion des papiers de travail électroniques), et les accélérateurs de tests : outils qui automatisent les performances des tests d'audit (comme les outils d'analyse des données).

7.1 Facilitateurs d'audit

Papiers de travail électroniques

Bien que non spécifique aux audits des SI, la gestion électronique de documents peut se révéler très utile. Ces solutions permettent une gestion centralisée et l'archivage des papiers de travail, l'automatisation des processus d'audit, le suivi des versions, de la clôture de session électronique, etc. Plusieurs fournisseurs sur le marché proposent ce type d'outils. Il est important d'étudier les fonctionnalités de ces outils. Par exemple, peut-il traiter plusieurs audits simultanément ? Il convient de définir, avant même la mise en place de n'importe quel outil, les impératifs fonctionnels de l'audit. Mais le contenu de l'outil lui-même est peut-être plus important encore. Intègre-t-il des suggestions pour les procédures d'audit ou les activités de contrôle ? Les responsables de l'audit interne devront certainement adapter la base de connaissance incluse dans l'outil, mais cette dernière peut donner un point de départ intéressant.

Logiciel de gestion de projet

Le logiciel de gestion de projet, qui n'est pas nécessairement spécifique à l'audit, programme le plan de travail, définit qui est responsable de quelle tâche, suit les jalons du projet et les livrables, et peut être utilisé par la fonction d'audit des SI pour obtenir davantage de cohérence et des reportings supplémentaires lors des missions. Quelque 35 % des organisations interrogées lors de l'enquête GAIN 2004 utilisent un logiciel de gestion de projet.

Logiciel de diagrammes de circulation

Un logiciel qui peut représenter graphiquement les flux de transactions ainsi que les principales étapes des processus, est très utile, voire nécessaire, pour l'illustration des cheminements, en particulier à des fins de conformité avec la loi Sarbanes-Oxley. Le stockage électronique des représentations graphiques des processus permet de mettre à jour plus aisément les diagrammes de circulation à mesure que les processus changent et facilitent le stockage et le partage. Quelque 59 % des organisations interrogées lors de l'enquête GAIN 2004 utilisent un logiciel de création de diagrammes de circulation.

Logiciel de suivi des questions en suspens

Ce type de logiciel, qui permet d'effectuer un suivi des questions restées en suspens ou des défaillances, est souvent intégré au logiciel de gestion documentaire, notamment ceux conçus à des fins de conformité à la loi Sarbanes-Oxley. Au nombre de ses fonctionnalités, on trouve généralement la possibilité d'assigner la responsabilité des procédures de remédiation, de définir les échéances et les livrables et de procéder à un suivi et à un reporting sur les avancées. Quelque 47 % des organisations interrogées lors de l'enquête GAIN 2004 utilisent un logiciel suivi des questions en suspens.

Site Web du département d'audit

Un certain nombre de départements d'audit se sont dotés d'un site Web. Ces sites fonctionnent généralement sur l'Intranet, mais peuvent aussi se trouver sur Internet. Les solutions Internet permettent le partage d'informations entre les organisations à l'échelle mondiale, mais posent des problèmes de confidentialité. Ces deux types de solutions offrent à la fonction d'audit interne la possibilité d'un partage et d'une communication centralisés de l'information. Elles peuvent être développées sur mesure ou acquises auprès de fournisseurs. Quelque 42 % des organisations interrogées lors de l'enquête GAIN 2004 disposent d'un site Web pour la fonction d'audit.

7.2 Accélérateurs de tests

Les accélérateurs de tests permettent d'automatiser des tâches d'audit chronophages, comme l'examen de vastes populations de données. En outre, le recours à un outil pour exécuter des procédures d'audit confère une certaine cohérence. Par exemple, si l'on utilise un outil pour évaluer la configuration de la sécurité d'un serveur, tous les serveurs testés au moyen de cet outil seront évalués par rapport aux mêmes critères. Exécuter ces procédures manuellement laisse du champ à une interprétation de la part de l'auditeur SI. Depuis peu, l'utilisation de ces outils permet aux auditeurs de tester la totalité d'une population de données, et non un simple échantillon de transactions, d'où un niveau d'assurance bien supérieur.

S'agissant des accélérateurs d'audit des SI, les responsables d'audit interne doivent avoir conscience des aspects suivants :

- Les outils sont onéreux. Il faut être certain que les avantages sont supérieurs aux coûts avant de s'engager dans la mise en place d'un outil.
- Les auditeurs SI devront être formés au nouvel outil. Il n'est pas rare de voir un outil rester inutilisé dans un département d'audit interne parce que personne ne sait

s'en servir. Ce genre de situation réduit considérablement le retour sur investissement de n'importe quel outil.

- L'outil aura également besoin d'un support, d'une gestion de patchs et de montées en version. Certains nécessitent aussi un serveur autonome. Pour cette raison, la sélection des outils doit s'opérer avec l'aide du département informatique.
- Dans certains cas, le management informatique ou les prestataires tiers peuvent ne pas autoriser les outils à accéder directement à l'environnement de production. Toute utilisation des outils et/ou des scripts doit faire l'objet d'une discussion préalable et d'une autorisation par le management informatique, et être entièrement testé avant d'être déployé.

Logiciel d'analyse de données

Ces outils permettent à l'auditeur SI de réaliser une analyse statistique robuste de vastes ensembles de données. Ils peuvent également être utilisés pour étayer les audits opérationnels ou de processus (par exemple, les examens des fraudes dans les créances fournisseurs), et ils peuvent faciliter plusieurs types des tests, comme la loi de Benford, échantillonnage cumulatif, etc. Lorsque l'on utilise un outil d'analyse des données, il faut tenir compte du fait qu'il peut être difficile d'extraire les données de la source originale. Il faut impérativement respecter les procédures d'audit des SI l'on veut s'assurer de l'exhaustivité et de l'exactitude de la donnée source. Certains des principaux prestataires dans ce domaine sont :

- ACL : http://www.acl.com/Default.aspx?bhcp=1
- Idea : http://www.audimation.com/product_feat_benefits.cfm
- Monarch : http://monarch.datawatch.com/
- SAS : http://www.sas.com/

Outils d'analyse de la sécurité

Un vaste ensemble d'outils permettent d'examiner une large population de dispositifs et/ou d'utilisateurs, et de déceler les expositions à des risques liés à la sécurité. Il existe de multiples types d'outils d'analyse de la sécurité, que l'on peut globalement répartir entre les catégories suivantes :

Outils d'analyse de réseau – Ces outils sont des programmes logiciels que l'on peut lancer sur un réseau pour recueillir des informations concernant ce dernier. Classiquement, les pirates informatiques utilisent l'un de ces outils au début d'une attaque afin de déterminer à quoi ressemble le réseau. Les auditeurs SI peuvent y recourir pour diverses procédures d'audit, notamment :

- La vérification de l'exactitude des diagrammes de réseau par une cartographie du réseau d'entreprise.
- L'identification des dispositifs clés du réseau qui appellent une attention supplémentaire de la part des auditeurs.
- La collecte des informations concernant le trafic autorisé sur un réseau (étayant directement le processus d'évaluation des risques liés aux SI).

Il est possible d'obtenir une liste des 75 meilleurs outils sur www.insecure.com.

Outils de piratage – La plupart des technologies, lorsqu'elles ne sont pas personnalisées, souffrent d'un certain nombre de vulnérabilités standard, comme l'existence d'identifiants, de mots de passe ou de paramètres par défaut. Les outils de piratage offrent une solution automatisée pour vérifier ces vulnérabilités. Ces outils peuvent cibler les pare-feux, les serveurs, les réseaux et les systèmes d'exploitation. Nombreux de ces outils sont « prêts à brancher » : l'auditeur SI les branche sur tout ce qu'il souhaite analyser, et peut partir pendant qu'il laisse l'outil tourner. Lorsqu'il revient, quelques heures plus tard ou le lendemain, l'outil aura élaboré un rapport sur toutes les vulnérabilités identifiées.

Il est important que l'auditeur SI exploite ce type d'outils pour plusieurs raisons, et notamment parce que ce sont les outils qu'un pirate informatique utiliserait pour monter une attaque contre l'organisation. Cette dernière doit disposer au moins du même niveau d'information que le pirate. Il est important de noter qu'il est potentiellement dangereux de faire tourner certains de ces outils, parce qu'ils peuvent compromettre l'intégrité des systèmes qu'ils scannent. L'auditeur SI doit examiner avec le responsable de la sécurité l'utilisation qu'il prévoit de faire de ces outils et coordonner les tests avec la direction des systèmes d'information afin de veiller à ce que le calendrier des tests n'affecte pas la production. Dans certains cas, le responsable de la sécurité ou les administrateurs systèmes emploient déjà régulièrement certains de ces outils dans le cadre des processus de gestion des systèmes. Si tel est le cas, on peut exploiter ces résultats dans les audits des SI, s'ils sont correctement conçus et exécutés. Une liste des 75 meilleurs outils est disponible à l'adresse www.insecure.com.

Outils d'analyse de la sécurité des applications – Si une organisation utilise une vaste application intégrée (par exemple un système d'ERP comme SAP ou Oracle), nombre des contrôles internes clés sont fortement liés à la sécurité. Ainsi, la société XYZ peut avoir pour politique de faire avaliser tous les chèques d'un montant supérieur à 10 000 dollars avant de les émettre. Il s'agit bien sûr d'un contrôle important. La société XYZ peut, par exemple, avoir configuré son système Oracle de sorte que tous les chèques d'un montant supérieur à ce seuil soient automatiquement placés dans une file d'attente pour que quelqu'un les autorise et les édite. Cet exemple illustre bien la manière dont les contrôles informatiques peuvent venir étayer la politique de l'entreprise. Supposons maintenant que tous les utilisateurs du système Oracle aient un accès intégral au système. Alors, n'importe quel utilisateur pourrait se rendre dans la file d'attente et autoriser et éditer le chèque. C'est pour cette raison que la sécurité au niveau de l'application doit être bien conçue et mise au point en

parallèle des processus et des contrôles applicatifs. Cet exemple montre en outre pourquoi tout type d'audit (financier, de processus, opérationnel ou des SI) s'inscrivant dans un vaste environnement d'applications intégrées doit, pour être efficace, inclure une composante de sécurité.

Malheureusement, pour de nombreux fournisseurs, l'intégration de fonctionnalités venant étayer les audits portant sur la sécurité de l'accès aux applications ne figure pas nécessairement au rang des priorités, et beaucoup ont tendance à se concentrer davantage sur le fonctionnement opérationnel. Par conséquent, réaliser un audit de sécurité des accés aux applications se révèle souvent extrêmement malaisé et chronophage. Il est possible d'accélérer ces audits en utilisant un outil d'analyse de la sécurité des applications, qui sont, pour la plupart, spécialisés sur diverses applications (PeopleSoft, SAP ou Oracle) et analysent la sécurité de l'accès au regard de règles préconfigurées. Ces outils peuvent également évaluer la séparation des fonctions au sein d'une application. Le responsable de l'audit interne doit être conscient du fait que la plupart de ces outils sont assortis d'un ensemble de règles préconfigurées ou dont le fournisseur proclame qu'il s'agit des « bonnes pratiques ». Toujours selon la théorie du flocon de neige, toute mise en place de l'un de ces outils devra s'accompagner d'un projet solide visant à créer l'ensemble de règles pertinent pour cette organisation en particulier. À défaut, les rapports d'audit contiendront un certain nombre de faux positifs (erreur de type I) ou de faux négatifs (erreur de type II).

Les principaux fournisseurs dans ce domaine sont :

- Approva : http://www.approva.net/
- LogicalApps : http://www.logicalapps.com/
- Virsa : http://www.virsa.com/
- Q Software : http://www.qsoftware.com/index.htm
- Control Solutions International : http://www.csi4sap.com/en/home/

Si l'audit des SI existe depuis des années, il est en constante évolution. Par conséquent, le responsable de l'audit interne doit en permanence s'adapter et faire évoluer son approche ainsi que le périmètre de l'audit des SI afin d'exécuter les procédures nécessaires pour s'assurer du respect des exigences de conformité et de la couverture du risque global auquel est confronté l'organisation.

Bien que ce guide n'ait pas toutes les solutions et que, dans certains cas, il soulève davantage de questions qu'il n'apporte de réponse, il devrait constituer un outil qui aidera le responsable de l'audit interne face à cette évolution. Voici une liste de questions qui devraient aider le responsable de l'audit interne, confronté à ces problèmes dans le cadre de son organisation :

- L'organisation a-t-elle clairement défini ce que représentent les SI dans son cas particulier ? Les domaines de responsabilité du directeur des systèmes d'information sont-ils clairement définis ? L'audit des SI prend-il en compte tous ces domaines lorsqu'il évalue les risques et définit l'univers des SI à auditer ?
- La fonction d'audit évalue-t-elle chaque année les risques efficacement ? Des spécialistes des technologies d'infrastructure, des applications et des processus informatiques interviennent-ils tous dans cette évaluation ?
- L'évaluation des risques liés aux SI prend-elle en considération l'architecture et la configuration technologiques spécifiques employées par cette organisation ?
- Comment les risques liés aux SI sont-ils quantifiés ? En estime-t-on aussi bien l'impact que la probabilité d'occurrence ? Au regard de quel référentiel et de quelles bonnes pratiques ces estimations sont-elles effectuées ?
- Des audits des SI sont-ils prévus à tous les niveaux de l'environnement du SI ? Si non, pourquoi ? Des circonstances spécifiques s'appliquent-elles ? Le plan d'audit des SI est-il sous-optimal ?
- Comment calcule-t-on le budget des audits des SI ? Suffisamment d'informations ont-elles été recueillies au début de l'audit pour que l'on puisse calculer le budget avec précision ? La configuration spécifique de la technologie a-t-elle été prise en compte ?
- Comment les procédures d'audit des SI sont-elles définies ? Sont-elles développées en interne pour l'environnement spécifique de l'organisation, ou utilise-t-on les listes de vérification disponibles sur le marché ?
- L'organisation a-t-elle instauré un cadre ou des normes de contrôles informatiques ? Si oui, lesquels ? Si non, a-t-on établi en interne des références minimales pour les contrôles et la sécurité ? Si non, le responsable de l'audit interne a-t-il recommandé la mise en place d'un cadre de contrôle informatique et de sécurité ainsi que des références minimales dans le cadre de l'audit du management et de la gouvernance des SI ?
- Utilise-t-on des outils pour accélérer l'audit des SI (comme des accélérateurs de tests ou des facilitateurs) ? Si non, pourquoi ? Si oui, ont-ils fait l'objet de tests approfondis et reçu une autorisation de la direction des systèmes d'information ?
- La dotation en personnel pour les audits des SI est-elle satisfaisante ? Fait-on appel à des spécialistes pour des diverses technologies (par exemple des personnes différentes pour les applications et pour les réseaux) ? Si non, pourquoi ? Comment la qualité et la pertinence des papiers de travail de l'audit des SI sont-elles analysées ?
- A-t-on défini une stratégie de formation pour les auditeurs SI ? Prend-elle en compte toutes les couches de l'environnement de SI ?
- Les auditeurs des SI évaluent-ils chaque année les risques et problématiques informatiques émergents afin d'en déterminer l'importance pour l'organisation ? Comment l'organisation identifie-t-elle ces problématiques émergentes ?
- La fonction d'audit a-t-elle comparé la fonction d'audit des SI aux bonnes pratiques du secteur ? Recourt-on à l'enquête GAIN ou à d'autres référentiels pour faciliter cette démarche ?
- Tous les audits de processus comprennent-ils des procédures qui évaluent les paramètres de configuration des applications ? Comment sont-ils coordonnés entre les ressources d'audit (processus ou SI) ?

D'après la loi de Moore, la technologie ne cesse d'évoluer. Cette annexe porte sur plusieurs technologies récentes qu'un responsable de l'audit interne doit connaître, ainsi que sur leur impact potentiel sur l'organisation et sur la fonction d'audit des SI. Il ne s'agit pas de dresser ici une liste détaillée de toutes ces nouvelles technologies, mais de donner un aperçu de quelques-unes des grandes problématiques actuelles.

Il est probable que ces questions diffèrent d'un environnement à l'autre (théorie du flocon de neige) et qu'elles induisent un risque plus ou moins élevé en fonction du secteur d'activité, de la technologie et des processus considérés. Elles sont présentées ci-après sans ordre précis, ainsi que les risques et les recommandations qui y sont associés. L'objectif est d'amener le responsable de l'audit interne à réfléchir sur son environnement et à se demander si ses procédures d'audit actuelles lui permettront de bien évaluer ces aspects.

A.1 Réseaux sans fil

Les réseaux sans fil se multiplient dans les organisations, car ils sont utiles et peuvent contribuer directement à la réalisation des objectifs de l'entreprise. Ils sont également faciles à mettre en place (quiconque a installé un réseau sans fil dans un logement pourra probablement le confirmer) et constituent un point d'accès potentiel au réseau de l'entreprise. Les responsables de l'audit interne doivent se préoccuper des problèmes de sécurité posés par les réseaux sans fil qui ont reçu le feu vert de l'organisation, mais aussi des problèmes liés aux réseaux sans fil installés sans autorisation.

Risques

Intrusion – Les réseaux sans fil sont susceptibles de laisser des utilisateurs non autorisés pénétrer sur le réseau de l'entreprise.

Écoute clandestine – Les réseaux sans fil sont susceptibles de laisser du personnel non autorisé accéder à des informations confidentielles qu'ils acheminent.

Détournement – Un utilisateur non autorisé peut détourner la session d'un utilisateur autorisé connecté à un réseau sans fil pour accéder au réseau de l'entreprise.

Gestion des radiofréquences (RF) – Il se peut que les transmissions d'un réseau sans fil arrivent là où elles ne devraient pas, ce qui est susceptible d'avoir des répercussions. Par exemple, un hôpital est doté d'équipements sensibles aux ondes hertziennes, qui ne doivent donc pas être exposés à des réseaux sans fil.

Recommandations

Il convient de procéder à un audit approfondi des réseaux sans fil, en se concentrant sur les deux points suivants :

- L'organisation a très probablement différents réseaux sans fil autorisés et mis en place pour répondre à un objectif précis. La fonction informatique doit évaluer ces réseaux et vérifier que la sécurité et les contrôles qui y sont associés sont conformes aux objectifs du management.
- Au sein de l'organisation, certains utilisateurs peuvent avoir installé des réseaux sans fil non autorisés. La fonction d'audit des SI doit appliquer des procédures visant à déterminer si de tels réseaux existent et à prendre des mesures appropriées. C'est une tâche plus difficile que de veiller à la sécurité et au contrôle, et l'auditeur SI devra probablement se rendre sur les sites de l'entreprise afin de détecter, au moyen d'une antenne, la présence de systèmes sans fil.

L'auditeur SI doit, au minimum, obtenir et examiner une liste de tous les réseaux sans fil autorisés par l'organisation. L'entreprise doit établir des politiques et des procédures applicables à ce type de réseau et formuler des recommandations pour leur sécurité et leur contrôle, notamment le chiffrement des données et l'authentification pour l'accès à des réseaux sans fil. L'auditeur SI doit analyser la configuration des réseaux sans fil connus, afin d'en vérifier la conformité avec les politiques et procédures définies. Il doit en outre identifier les éventuels réseaux sans fil non autorisés et prendre, le cas échéant, des mesures correctives appropriées.

A.2 Systèmes mobiles

La plupart des organisations reconnaissent l'utilité des systèmes mobiles, tels que le Blackberry, les assistants numériques personnels *(Personal Digital Assistants – PDA)*, les téléphones intelligents *(smart phones)* ou les dispositifs sans fil TELXON, et y recourent largement pour faciliter la réalisation de leurs objectifs. Cependant, toutes les organisations ne se rendent pas compte du risque associé à l'utilisation de ces dispositifs.

Risques liés aux systèmes mobiles

Bon nombre des systèmes mobiles servent au stockage de données critiques pour l'entreprise. S'ils ne sont pas configurés de manière sécurisée, leur perte ou leur vol peut compromettre la confidentialité de ces données. La transmission de données vers les systèmes mobiles n'est pas non plus toujours sécurisée, ce qui peut, là encore, nuire à la confidentialité ou à l'intégrité des informations envoyées. En outre, ces systèmes sont souvent utilisés par la direction, d'où un risque à l'échelle de toute l'entreprise. De plus, ils peuvent permettre d'accéder à distance aux réseaux de l'entreprise et, dans le cas des TELXON et de systèmes similaires, de lancer certaines opérations. Imaginons, par exemple, qu'une société de distribution de boissons équipe ses livreurs de systèmes sans fil qui permettent le suivi du stock au fur et à mesure que les produits sont livrés aux clients.

Recommandations pour les systèmes mobiles

L'auditeur SI doit examiner la gestion des systèmes mobiles en prêtant attention, au minimum, aux aspects suivants :

Achat – Procédure suivie par un utilisateur pour acquérir un système mobile.

Normalisation – Les systèmes mobiles répondent-ils à une norme standard?

Sécurité de la configuration – Quelles politiques et procédures ont été établies pour constituer les principes de base de la sécurité des systèmes mobiles ?

Transmission de données – Comment la transmission de données est-elle contrôlée ?

Accès au réseau de l'entreprise – Les systèmes mobiles permettent-ils d'accéder au réseau de l'entreprise ? Si tel est le cas, comment cet accès est-il contrôlé ?

Perte ou vol – Comment l'entreprise peut-elle déterminer si des systèmes mobiles ont été perdus ou volés, et faire en sorte qu'ils ne soient plus utilisables ?

Logiciel d'interface – Si les systèmes mobiles servent à lancer certaines opérations, par quelle interface ces instructions sont-elles communiquées aux applications concernées ?

A.3 Interfaces

Les environnements des SI complexes nécessitent souvent des interfaces complexes pour l'intégration d'applications critiques. Même les environnements très étendus qui utilisent des systèmes d'ERP ont souvent besoin, eux aussi, d'interfaces sophistiquées avec d'autres applications distribuées, telles que des systèmes Internet. Les interfaces peuvent reposer sur un intergiciel *(middleware)*, qui sert de point central pour la communication et la coordination de ces équipements. Malgré le rôle important qu'ils jouent dans le traitement d'opérations de bout en bout, les interfaces et les intergiciels ne sont généralement pas pris en compte dans les plans d'audit. L'une des raisons en est peut-être la difficulté à rattacher les interfaces à une catégorie précise. En effet, par leur fonction, les interfaces s'apparentent à une infrastructure ou à une technologie, mais sont en fait des applications logicielles.

Risques liés aux interfaces

Les interfaces, et en particulier les intergiciels, forment une composante essentielle pour le traitement d'opérations de bout en bout. Elles doivent, au minimum, permettre de transférer des données d'un système à un autre, et, au maximum, transformer ces données, effectuer certains calculs ou modifier des données selon un algorithme. Les interfaces peuvent également être à l'origine d'une faille pouvant entraîner un arrêt complet de l'organisation. Supposons une société XYZ, qui établit des états financiers consolidés au moyen de systèmes d'ERP. Ses différents pôles sont tous dotés d'interfaces, qui relient divers systèmes disparates au système central de l'entreprise. On dénombre environ 200 interfaces, qui utilisent toutes un seul serveur intergiciel et une seule application. Si ce serveur tombe brusquement en panne, les activités de l'entreprise en seront gravement affectées.

Recommandations pour les interfaces

Le responsable de l'audit interne doit veiller à ce que le champ de l'audit et de l'évaluation du risque lié aux SI prenne en compte les interfaces et les intergiciels, en particulier les aspects suivants :

Utilisation d'un logiciel pour la gestion des interfaces – Le logiciel traite-t-il les données ou ne fait-il que les transférer d'un endroit à un autre ?

Identifiants des interfaces – Le logiciel d'interface aura probablement besoin d'accéder aux systèmes vers lesquels/depuis lesquels il transfère des données. Comment cet accès est-il géré ? Des identifiants génériques sont-ils utilisés ? À quel type d'accès correspondent-ils et qui dispose d'un accès pour les utiliser ?

Annuaires d'interfaces – Toutes les données sont-elles transférées via un seul annuaire d'interfaces ? Qui y a accès ? Comment cet annuaire est-il sécurisé et quels contrôles lui sont appliqués ? Un employé, dans l'un des pôles de l'entreprise, y a-t-il accès, par exemple pour télécharger un fichier destiné à permettre le traitement d'opérations ? Si tel est le cas, cet annuaire contient-il aussi des données servant à effectuer des virements ou des paiements électroniques vers l'extérieur ? Comment l'accès de l'employé à ces ensembles de données est-il restreint ? Les données sont-elles mélangées ?

Types d'interfaces – Quelles interfaces sont utilisées ? Fonctionnent-elles en temps réel ou par lots ? Quelles opérations supportent-elles ? Lancent-elles le traitement d'autres opérations (par exemple des ordres de vente interfacés, qui lancent la livraison de produits ?).

A.4 Gestion des données

Les organisations automatisent un nombre croissant de leurs processus et fonctions. En même temps, les coûts de stockage des données ne cessent de baisser. Aujourd'hui, même les micro-ordinateurs peuvent être dotés d'un disque dur d'au moins 250 Go, soit bien davantage que la capacité dont disposaient les gros serveurs il y a encore cinq ans. Ces évolutions multiplient les solutions pour le stockage d'importants volumes de données. Aujourd'hui, il n'est pas rare qu'une entreprise de taille moyenne stocke et gère plusieurs téraoctets. Cependant, alors que les organisations commencent à administrer ces vastes gisements de données, bien des problèmes se posent.

Risques liés à la gestion des données

L'incapacité à gérer des gisements de données, ou des réseaux de stockage SAN *(storage area networks)*, peut entraîner l'indisponibilité de données critiques pour l'entreprise. Les organisations doivent par conséquent veiller à l'intégrité des solutions de stockage. La sauvegarde ou la refonte d'un réseau de stockage contenant six téraoctets de données peut toutefois se révéler difficile. Il faut donc développer de nouvelles technologies de gestion et de maintenance, et définir de nouveaux processus de gestion. De surcroît, la croissance du stockage de données coïncide avec l'adoption d'un nouveau vaste corpus de textes législatifs et réglementaires portant sur la gestion des données. Par conséquent, la gestion des

données d'une organisation doit également être conforme à de multiples obligations juridiques et sectorielles nouvelles.

Recommandations pour la gestion des données
Il convient de réaliser un examen approfondi de la gestion des données, en prêtant attention, au minimum, aux aspects suivants :

- **Classification des données** – L'organisation a-t-elle procédé à une classification de ses données ? Quelles catégories de données ont été définies et selon quels critères ?
- **Propriété des données** – L'organisation a-telle formellement défini qui est propriétaire des données ? Les responsabilités de ces propriétaires ont-elles été formulées par écrit ?
- **Conservation des données** – Une stratégie de conservation des données a-t-elle été établie ? Même les solutions de stockage de grande capacité peuvent arriver à saturation, contraignant l'organisation soit à supprimer des données, soit à en transférer vers une autre solution de stockage, par exemple le système d'archivage. Quelle est la politique d'archivage/de conservation en place ? Fait-elle obstacle à la réalisation des objectifs de l'organisation ou, au contraire, la favorise-t-elle ? Si un audit doit être réalisé, les données concernées seront-elles disponibles ou bien auront-elles été archivées ou supprimées ? Si elles ont été archivées, peut-on les retrouver facilement ?
- **Outils d'archivage et de conservation des données** – Si une stratégie de conservation des données a été définie, elle peut nécessiter des outils, tels que des logiciels ou des supports d'archivage. Il se peut aussi qu'il faille auditer ces outils, afin de vérifier s'ils permettent une mise en œuvre efficace des procédures requises.
- **Gestion des données** – Comment les données sont-elles gérées ? Quelles sont les tâches journalières/hebdomadaires/autres à effectuer pour veiller à l'intégrité des données ? Qui effectue ces tâches et selon quelle procédure ?

A.5 Protection de la vie privée

La protection de la vie privée et les droits des consommateurs sont deux grands thèmes d'actualité. Aujourd'hui, les grandes entreprises doivent se conformer à un grand nombre de lois relatives aux données à caractère personnel. Dans certains cas, ces dispositions peuvent être très différentes les unes des autres, au point de se contredire parfois. Ainsi, une grande organisation qui opère en Europe et en Amérique du Nord devra appliquer la Directive de l'UE sur la protection des données personnelles, la Loi canadienne de 2000 sur la protection des renseignements personnels et les documents électroniques, un certain nombre de règlements de divers États des États-Unis, voire des dispositions sectorielles telles que, aux États-Unis, la Loi *Health Insurance Portability and Accountability Act de 1996* ou la Loi Gramm-Leach-Bliley Act de 1999. Toutes ces exigences sont différentes. Si, par exemple, une organisation souhaite créer un site Web proposant des jeux ou des contenus auxquels les enfants peuvent accéder, elle doit également bien connaître les lois relatives aux données personnelles et à la protection des enfants.

Risques liés à la protection de la vie privée
La non-conformité à certaines lois sur les données personnelles peut être sanctionnée par une amende et/ou par des poursuites pénales. De plus, elle est susceptible d'entacher la valeur d'une marque. Prenons l'exemple d'une marque de céréales qui, pour promouvoir ses produits, met des jeux en ligne sur son site Web. Un certain nombre d'enfants s'inscrivent sur ce site pour jouer. Un pirate informatique réussit à accéder à la liste des utilisateurs du site, qui contient des informations permettant d'identifier ces enfants. Le *Wall Street Journal* publie alors un article sur cette entreprise qui laisse filtrer sur Internet des données permettant d'identifier des enfants. Quelles seraient les conséquences d'une telle situation ? Il est difficile de quantifier l'impact sur l'organisation, mais, selon toute probabilité, la valeur actionnariale en pâtirait.

Recommandations pour la protection de la vie privée
Il convient de réaliser un audit de la protection des données personnelles en prêtant attention, au minimum, aux aspects suivants :

- **Législation et réglementation applicables à l'organisation** – L'organisation a-t-elle identifié tous les textes législatifs et réglementaires auxquels elle doit se conformer ?
- **Responsabilités en matière de protection des données personnelles** – Un poste de directeur de la protection des données personnelles a-t-il été créé ? Quelles responsabilités lui reviennent ? Quel est le rôle du conseiller juridique en ce qui concerne la protection des données personnelles ?
- **Politiques et procédures** – Des politiques et des procédures ont-elles été définies pour la création, le stockage et la gestion des données de l'entreprise ? Comment sont-elles mises en œuvre, et comment l'organisation veille-t-elle à ce qu'elles soient respectées ?
- **Conformité** – Quelles sont les tâches servant spécifiquement à assurer la conformité ? L'organisation impose-t-elle le chiffrement des données ? Si tel est le cas, quelles méthodes sont utilisées à cette fin ? Les techniques de développement Web sont-elles mises à jour pour inclure, par exemple, des politiques d'acceptation volontaire ?

A.6 Séparation des fonctions

À mesure que les organisations intègrent des applications plus larges et plus complexes, la séparation des fonctions dépend moins du rôle concerné que du type d'opérations que l'utilisateur peut réaliser à l'intérieur du système. La séparation adéquate des fonctions est donc en grande partie déterminée par

le niveau de sécurité associé aux applications. Cependant, en même temps, cette sécurité est toujours plus complexe et nécessite des compétences plus pointues. C'est pourquoi la séparation des fonctions est imparfaite dans de nombreuses organisations. Enfin, il est plus difficile de la soumettre à un audit efficace et efficient, étant donné la complexité de la sécurité au niveau des applications.

Risques liés à la séparation des fonctions

Une mauvaise séparation des fonctions peut exposer une organisation au vol, à la fraude ou à une utilisation non autorisée des ressources d'information. De plus, elle est susceptible d'empêcher la conformité à la loi Sarbanes-Oxley. Plusieurs des déficiences importantes (material weaknesses) dont un certain nombre de sociétés cotées en Bourse ont fait état à la date de publication du présent guide (2004) étaient imputables à une séparation inappropriée des fonctions.

Recommandations pour la séparation des fonctions

Il convient de réaliser un audit de la séparation des fonctions, qui doit porter sur les aspects suivants :

Comment la séparation des fonctions est-elle gérée et contrôlée ? – Quels sont les processus, les intervenants et les outils auxquels on recourt pour gérer la séparation des fonctions ?

Définir les incompatibilités – L'organisation a-t-elle établi une liste détaillée de toutes les fonctions présumées incompatibles entre elles ? Comment cette liste a-t-elle été modifiée pour les pôles de l'entreprise qui disposent d'un effectif beaucoup plus restreint que les autres ? Qui a participé à l'élaboration de cette liste ? Toutes les parties prenantes clés ont-elles été associées à la définition des incompatibilités et à la validation de la liste ?

Déterminer les lacunes spécifiques – L'organisation a-t-elle utilisé la liste des incompatibilités pour identifier certains rôles liés à la sécurité ou certains intervenants disposant de droits d'accès qui constituent une infraction à la séparation des fonctions ? Un outil est-il actuellement utilisé pour faciliter ce processus ? Si tel est le cas, comment est-il configuré ? Permet-il de surveiller et de traiter les incompatibilités en temps réel ?

Assigner les responsabilités – L'organisation a-t-elle formellement assigné à une personne ou à un rôle précis la responsabilité de la gestion et du contrôle de la séparation des fonctions ? Si tel est le cas, quelles tâches cette responsabilité implique-t-elle, et quand doivent-elles être menées à bien ? Est-ce que des politiques et des procédures sont en place pour donner des orientations à cette fin ?

Procéder à une analyse croisée des applications – Est-ce que des outils, des politiques et des procédures ont été instaurés pour gérer l'analyse de la séparation des fonctions entre différentes applications ? Exemple : la société XYZ recourt à un système SAP pour sa comptabilité et à un système PeopleSoft pour ses ressources humaines. Un utilisateur a accès aux deux systèmes et cet accès combiné induit des incompatibilités au niveau de la séparation des fonctions. L'analyse du système SAP ou du système PeopleSoft individuellement ne révèle pas d'incompatibilités. Seule une analyse croisée des applications permettrait de déceler les conflits.

A.7 Accès administrateur

Le personnel chargé d'administrer des systèmes dispose généralement de larges droits d'accès aux SI, car on suppose que leurs fonctions d'administration nécessitent ce niveau d'accès.

Risques liés aux accès administrateur

Les utilisateurs qui disposent d'un accès administrateur peuvent potentiellement assumer nombre de fonctions qui vont des responsabilités liées à leur mission de base. Ainsi, un utilisateur qui dispose d'un accès intégral à une application d'entreprise pourrait créer une facture, recevoir des marchandises et faire un chèque. Le même administrateur pourrait également effacer toutes les pistes d'audit. Et un utilisateur disposant d'un accès administrateur à la base de données de l'entreprise pourrait détourner tous les paiements électroniques.

À mesure que les organisations rendent leurs environnements SI plus automatisés et plus intégrés, les risques administrateurs liés à la comptabilité s'accroissent. Un administrateur système qui dispose d'un accès illimité à un système SAP complet a beaucoup plus de pouvoir qu'un administrateur système qui a, lui, un accès illimité à un système de stockage. Si l'accès administrateur ne peut être restreint de manière adéquate, il peut en découler un risque significatif, et, dans le cas où l'entreprise est cotée en Bourse, les auditeurs externes pourraient juger que la section 404 de la loi Sarbanes-Oxley n'est pas respectée. Pour les entreprises qui externalisent tout ou partie de leur environnement SI, ce risque est encore plus grand, pour deux raisons :

- Dans de nombreux cas, le prestataire extérieur travaille pour plusieurs organisations en mobilisant un large effectif : le plus souvent, au lieu d'affecter une équipe de 5 administrateurs à une seule organisation, on demande à 25 administrateurs de s'occuper collectivement de 5 organisations. Il est alors probable que ces 25 personnes disposent de larges droits d'accès.
- Nonobstant les dispositions contractuelles, le risque est toujours plus grand lorsqu'une personne qui n'est pas salariée de l'organisation dispose d'un accès administrateur aux systèmes.

Recommandations pour les accès administrateur

Dans tout environnement, un accès administrateur est nécessaire pour gérer les systèmes. Cependant, l'audit des SI doit permettre de veiller à ce que les administrateurs système aient uniquement accès aux données et aux fonctions dont ils ont besoin pour exécuter leurs tâches. Il convient de noter que celles-ci n'incluent pas de transactions fonctionnelles. Il n'ap-

partient pas aux administrateurs système d'enregistrer des transactions dans le grand livre, de rédiger des chèques ou d'éditer une fiche fournisseur. Ces intervenants ne devraient donc pas disposer d'un accès leur permettant d'exécuter ce type de tâche. On entend souvent l'argument selon lequel les administrateurs doivent pouvoir accéder à ces fonctions pour remédier aux pannes. Néanmoins, la plupart des réparations et des tests doivent être effectués dans l'environnement de test, et non dans l'environnement de production. Si l'environnement de test ne donne pas une représentation adéquate de la production, c'est le signe d'une faille dans le processus de développement des systèmes, et non de la nécessité d'élargir l'accès à l'environnement de production.

L'auditeur des SI doit également prêter attention aux aspects suivants :

Fractionnement de l'accès – On fractionne l'accès de telle sorte qu'il faut deux personnes pour exécuter une fonction donnée.

Identifiants génériques – Dans certains cas, une équipe administrative se partage un identifiant administrateur. L'auditeur SI qui analyse un rapport d'accès ne voit qu'un seul utilisateur, alors qu'en réalité, plusieurs utilisateurs recourent à cet identifiant. Il en découle un risque accru, car la piste d'audit est alors compromise.

Nombre de personnes disposant d'un accès administrateur – L'accès aux fonctions administrateur doit être limité à quelques administrateurs. Les membres du département informatique n'ont pas tous besoin d'un accès administrateur.

Gestion de la piste d'audit – Étant donné que les administrateurs disposent d'un large accès aux systèmes, l'un des seuls contrôles d'atténuation qui permet de prévenir les erreurs est la revue indépendante périodique des pistes d'audit. Cette revue peut être effectuée par le personnel chargé de l'audit des SI ou par un tiers indépendant (par exemple un directeur des systèmes d'information qui fait partie d'un autre département informatique). Il est indispensable de veiller à ce que, dans la mesure du possible, le personnel qui administre les systèmes ne puisse pas effacer des données de la piste d'audit, ce qui dépend souvent de la configuration des systèmes ou de la sécurité.

Utilisation d'identifiants de secours – On peut également utiliser des identifiants ou des mots de passe de secours pour atténuer le risque lié aux droits d'accès administrateur. À cette fin, on crée un compte avec un accès de type administrateur. Ce compte est verrouillé, et le mot de passe n'est connu que d'une personne au sein de l'organisation. Si une situation de crise survient, le personnel du support informatique va chercher le mot de passe correspondant à l'identifiant de secours. Il utilise cet identifiant pour exécuter les tâches requises et l'envoie à la personne responsable, qui verrouille alors le compte. Il existe aujourd'hui sur le marché un certain nombre de nouveaux outils qui permettent d'automatiser ce processus.

A.8 Contrôles configurables

Comme indiqué dans l'introduction au présent guide, aujourd'hui, beaucoup de contrôles clés reposent sur une technologie ou sont configurés dans des applications d'entreprise. Reprenons un exemple donné dans l'introduction, celui d'une triple concordance automatisée. Ce processus de rapprochement est contrôlé par un certain nombre de paramètres configurables dans l'application concernée (niveaux de tolérance, type de rapprochement par quantité ou par valeur, traitement des opérations pour lesquelles le rapprochement n'a pas été satisfaisant, écarts comptables, etc.).

Dans de nombreux cas, les contrôles configurables sont les contrôles primaires qui gèrent et supervisent le traitement des transactions via tel ou tel processus. Or, l'audit des processus les néglige souvent.

Risques liés aux contrôles configurables

Lorsque l'audit des processus ne tient pas compte des contrôles d'application configurables, les procédures d'audit risquent d'être inefficaces, et les conclusions de l'audit d'être inexactes. De plus, il est souvent nettement plus rapide d'examiner un paramètre configuré en ligne que de sélectionner et d'examiner un échantillon de 60 opérations. Les procédures d'audit risquent donc d'être également inefficientes si les vérifications ne sont pas axées sur les contrôles configurables.

Recommandations pour les contrôles configurables

Il convient de ne pas évaluer les contrôles configurables dans le cadre d'un audit des SI distinct. Tous les audits orientés sur les processus doivent, dans le cadre d'un audit global, évaluer les paramètres configurables qui permettent le contrôle de tel ou tel processus. Des problèmes de coordination peuvent se poser, car les auditeurs SI devront probablement travailler main dans la main avec les auditeurs des processus, de manière à déterminer lesquels des paramètres sont importants et mettre en œuvre les procédures d'audit technique nécessaires.

Le responsable de l'audit interne doit examiner le plan d'audit pour tous les audits de processus planifiés. Il doit se demander, le cas échéant, pourquoi ce plan ne comporte pas de tests des contrôles configurables. Cependant, l'absence de ces tests ne constitue pas forcément une lacune. En effet, il peut exister différentes raisons valables pour lesquelles un audit ne s'intéresse pas aux contrôles configurables. Si, en revanche, l'audit des processus porte sur les contrôles configurables, il est essentiel de définir comment ces contrôles seront testés. L'utilisation d'un tableau de configuration pour évaluer les paramètres nécessite un ensemble de compétences très différent de celui requis pour examiner un échantillon de 60 opérations. Les responsables de l'audit interne qui sont efficaces élaborent un plan d'audit qui déploiera le bon ensemble de

compétences au bon endroit. Concernant les audits de processus, cela peut consister à coordonner les interventions de plusieurs auditeurs dans le cadre d'un seul et même audit. Une telle coordination est susceptible de poser des problèmes de logistique, mais améliore a priori l'efficacité de l'audit.

A.9 Piratage

Le piratage informatique n'a jamais été aussi fréquent qu'aujourd'hui. À mesure que les organisations automatisent leurs activités, elles numérisent un nombre croissant d'actifs. Pour certaines entreprises, la gestion de ces actifs numériques peut même être plus essentielle que la protection de leurs actifs physiques. Internet a donné naissance à un réseau mondial sur lequel des actifs numériques piratés peuvent être diffusés rapidement et de façon anonyme.

Risques liés au piratage

Le risque de piratage augmente avec la valeur des actifs numériques.

Certaines organisations et certains secteurs d'activité considèrent le piratage comme l'un des plus grands risques auxquels ils sont aujourd'hui confrontés. Les récents litiges qui ont opposé des maisons de disques à plusieurs sites de partage de musique en ligne (Napster, par exemple) en sont un exemple parmi bien d'autres.

Il est difficile de quantifier les coûts financiers directs du piratage, mais de nombreuses organisations estiment que son incidence sur le résultat des entreprises se chiffre en dizaines, voire en centaines ou en millions de dollars.

Recommandations concernant le piratage

Il convient de réaliser un audit de la gestion des actifs numériques, qui doit porter sur les aspects suivants :

Inventaire de tous les actifs numériques gérés par l'organisation – L'organisation tient-elle à jour une liste de tous ses actifs numériques, ainsi que de leur emplacement physique et logique ?

Classification – L'organisation a-t-elle classifié ses actifs numériques ? Si tel est le cas, selon quels critères ? Quels niveaux ont été définis ?

Stockage – Où les actifs numériques sont-ils stockés ? Comment ? Des sauvegardes appropriées sont-elles effectuées ? Si ces sauvegardes sont stockées sur un site extérieur, comment sont-elles sécurisées et contrôlées ?

Chiffrement – Les actifs numériques font-ils l'objet d'un chiffrement ? Si tel est le cas, au moyen de quelles technologies ? Les méthodes de chiffrement sont-elles pertinentes pour ces catégories d'actifs ?

Accès administrateur et de tiers – Si les actifs numériques sont sécurisés, quelles autres personnes y ont accès ? Exemple : La société XYZ réalise son dernier *blockbuster* estival. Elle a consacré 200 millions de dollars au développement et au marketing de ce film. Elle l'a stocké sous forme numérique sur des serveurs de montage de grande capacité, comme le ferait toute entreprise prudente. Ces données sont sauvegardées et stockées sur un site extérieur. À l'intérieur de la chaîne de stockage, l'un des intervenants (par exemple le responsable du stockage sur ce site) diffuse sur Internet une copie du film non terminé, plusieurs semaines avant sa sortie en salles, ce qui réduit nettement les recettes brutes d'exploitation. Ce fiasco résulte d'une volonté initiale d'appliquer de bons contrôles informatiques (sauvegardes, notamment). Ce paradoxe contraint l'auditeur des SI à réfléchir à de nouveaux moyens permettant de mieux sécuriser et contrôler les transmissions numériques.

Transport et transmission – Les mêmes problèmes que ceux décrits ci-dessus se posent aussi pour le transport et la transmission d'actifs numériques. Tout fichier numérique non chiffré qui est envoyé par courrier électronique risque d'être détourné. L'organisation a-t-elle défini des politiques et des procédures solides pour le transport et/ou la transmission de ses actifs numériques ?

Autres ressources

Organismes professionnels

- Information Systems Audit and Control Association (ISACA) – www.isaca.org
  - Deux types de certifications : CISA *(Certified Information Systems Auditor)* et CISM *(Certified Information Systems Manager).*
- The Institute of Internal Auditors (IIA) – www.theiia.org
  - Certification CIA *(Certified Internal Auditor)*
  - Lettre d'information électronique gratuite *ITAudit*, qui présente notamment des ouvrages de référence.
- Information Systems Security Association (ISSA) – www.issa.org
  - Assistance aux professionnels certifiés dans le domaine de la sécurité de l'information.
  - ISC2 administre le processus de certification, mais n'est pas un organisme professionnel.
- American Institute of Certified Public Accountants (AICPA) – www.aicpa.org
  - Certification CPA *(Certified Public Accountant).*

Sites Web utiles

- http://www.csoonline.com
  - Ressources intéressantes, notamment des articles destinés aux responsables de la sécurité.
- http://www.whatis.com
  - Excellent site, qui permet de trouver rapidement des définitions relatives à diverses technologies, ainsi que des liens vers d'autres sites ayant trait aux SI.
- http://csrc.nist.gov
  - Site du Computer Security Research Center, financé par le NIST (National Institute of Standards and Technology).
- http://www.cyberpartnership.org
  - Le National Cyber Security Partnership est un parte-

nariat public-privé mis en place pour élaborer des stratégies et des programmes partagés, destinés à mieux sécuriser et à améliorer l'infrastructure d'information aux États-Unis.

- http://www.infosecuritymag.com/
  - Revue spécialisée dans la sécurité de l'information, qui traite de sujets d'actualité.
- http://www.itgi.org
  - Aide les chefs d'entreprise à instaurer un SI performant, correspondant à la mission et aux objectifs de leur société.

Éditeurs de logiciels et groupes d'utilisateurs

- Logiciels libres
  - Business Software Alliance œuvre pour un monde numérique sûr et respectueux du droit – http://www.bsa.org/usa/antipiracy/Free-Software-Audit-Tools.cfm
  - AuditNet® est un réseau de ressources à l'intention des auditeurs – http://www.auditnet.org
- Groupes d'utilisateurs
  - Americas' SAP Users' Group – www.asug.com
  - Independent Oracle Users Group – www.ioug.org
  - Quest International User Group (pour PeopleSoft/JD Edwards) – http://www.questdirect.org
  - SQL Server Worldwide Users Group – http://www.sswug.org
  - Annuaire Yahoo des groupes d'utilisateurs : http://dir.yahoo.com/Computers_and_Internet/Organizations/User_Groups

Michael Juergens, l'auteur principal de ce guide, a plus de 15 ans d'expérience professionnelle et travaille chez Deloitte depuis 1996, où il est actuellement responsable du pôle *Control Assurance* pour la région Sud-Ouest du Pacifique. Michael Juergens est spécialiste de l'évaluation des contrôles informatiquesI. C'est un intervenant nationalement reconnu dans le domaine des contrôles internes, qui s'est exprimé devant de multiples auditoires, notamment pour des organisations telles que l'IIA, l'ISACA, le SAP Users' Group aux États-Unis, le MIS Training Institute, ainsi que lors de nombreuses conférences nationales et internationales. Il siège au Professional Conferences Committee de l'IIA et supervise tous les cours de formation à l'audit des SI qui sont proposés par l'IIA. Michael Juergens est responsable en chef des contrôles internes pour de grandes multinationales. Il s'est notamment occupé de divers projets de contrôle interne, de projets de mise en conformité avec la loi Sarbanes-Oxley et d'audits d'attestation. Michael Juergens est titulaire d'un B.A. d'économie et d'un M.B.A. de la California Irvine University.

David Maberry, contributeur à ce guide, est *senior manager* du pôle *Audit and Enterprise Risk Services Control Assurance* de Deloitte à Los Angeles. Il dispose d'une grande expérience de la gestion du risque, des questions de conformité et de l'audit interne, et il est spécialiste des évaluations de la conformité à la loi Sarbanes-Oxley, du risque lié aux SI, des revues avant et après mise en œuvre, ainsi que des audits techniques portant sur un large éventail de systèmes et de plateformes. La vaste expérience qu'il a acquise sur le terrain lui permet d'analyser et d'optimiser les processus, dans la quasi-totalité des environnements. Avant d'entrer chez Deloitte, il a occupé pendant plus de 11 ans des postes d'encadrement opérationnel dans le secteur médical. David Maberry aide actuellement de nombreuses entreprises du classement *Fortune 500* dans leurs stratégies de mise en conformité de leurs procédures d'audit et d'évaluation de leurs activités.

Jeff Fisher, qui a contribué à la rédaction de ce guide, est *senior manager* du pôle *Audit and Enterprise Risk Services* de Deloitte & Touche. Il travaille dans ce cabinet depuis plus de huit ans et exerce les fonctions de chef de projet et de responsable de l'assurance qualité pour quelques-uns des plus importants clients de Deloitte. Jeff Fisher est spécialiste des audits et des évaluations de la sécurité des SI, de la gestion de projet et des diagnostics de conformité à la section 404 de la loi Sarbanes-Oxley. Il aide de nombreux clients de Deloitte à planifier et à déployer efficacement des processus d'évaluation de la conformité à la loi Sarbanes-Oxley, dans le monde entier. Jeff Fisher est titulaire d'un B.S. en comptabilité et systèmes d'information, délivré par la Ferris State University. Il est également CISSP *(Certified Information Systems Security Professional)* et CISA *(Certified Information Systems Auditor)*.

Eric Ringle, qui a contribué à la rédaction de ce guide, est *senior manager* du pôle *Audit and Enterprise Risk Services* de Deloitte & Touche. Il dispose de plus de 11 ans d'expérience et travaille pour des clients situés dans le monde entier. Eric Ringle est spécialiste des audits et des évaluations des systèmes d'information et des processus, de la gestion de projet, ainsi que des diagnostics de conformité à la section 404 de la loi Sarbanes-Oxley. Il aide de nombreux clients à planifier et à déployer des processus d'évaluation de la conformité à la loi Sarbanes-Oxley. Eric Ringle est titulaire d'un B.A. et d'un M.B.A. en comptabilité de l'Université du Michigan. Il est en outre CPA *(Certified Public Accountant)*, CITP *(Certified Information Technology Professional)* et CISA *(Certified Information Systems Auditor)*.

Réviseurs

Ont participé à la révision du projet de l'Advanced Technology Committee les instituts IIA dans le monde, l'American Institute of Certified Public Accountants, le Center for Internet Security, l'Université Carnegie-Mellon, le Software Engineering Institute, l'Information System Security Association, le IT Process Institute, la National Association of Corporate Directors et le SANS Institute. Ce guide a bénéficié des commentaires utiles des personnes et organisations suivantes :

- American Institute of Certified Public Accounts
- Institute of Internal Auditors, Australie
- Institute of Internal Auditors, Royaume-Uni
- Christopher Fox, PricewaterhouseCoopers, États-Unis
- David Bentley, consultant, Royaume-Uni
- E.W. Sean Ballington, PricewaterhouseCoopers, États-Unis
- Jay R. Taylor, General Motors Corp., États-Unis
- Larry Brown, The Options Clearing Corporation, États-Unis
- Lars Erik Fjortoft, Deloitte, Norvège
- Lily Bi, The Institute of Internal Auditors
- Stig J. Sunde, Riksrevisjonen/Office of the Auditor General, Norvège

GTAG

Management de l'audit des systèmes d'information

Les systèmes d'information (SI) font évoluer la fonction de l'audit interne. L'apparition de nouveaux risques impose de repenser les procédures d'audit pour bien gérer ces risques. Ce guide a pour objectif d'aider les responsables de l'audit interne et leur personnel chargé de superviser les audits des SI à comprendre les questions stratégiques liées à la planification et à la réalisation d'audits dans ce domaine. Il est centré sur les éléments essentiels de ces audits et sur les problématiques qui apparaissent.

À propos des guides pratiques d'audit des technologies de l'information ?

Élaborés par l'IIA, chaque guide est rédigé dans des termes simples et traite d'un thème d'actualité qui a trait à la gestion, au contrôle et à la sécurité des SI. Cette série de guides constitue un précieux outil pour les responsables de l'audit interne, qui peuvent ainsi s'informer sur les différents risques induits par la technologie et sur les pratiques recommandées.

Guide 1: *Les contrôles des technologies de l'information*

Guide 2: *Contrôles de la gestion du changement et des patchs : un facteur clé de la réussite pour toute organisation*

Guide 3: *Audit continu : répercussions sur l'assurance, le pilotage et l'évaluation des risques*

Vous pouvez consulter le site Web de l'IIA sur les questions technologiques : www.theiia.org/technology

The Institute of Internal Auditors
www.theiia.org